BẢN DỊCH TIẾNG VIỆT · DT124 · 18/10/2026

# Khảo sát tên miền phishing mới đăng ký trên quy mô lớn

Bài gốc: Examining newly registered phishing domains at scale.

Tác giả: Sharad Agarwal và Marie Vasek · Khoa Khoa học Máy tính, University College London (UCL), Vương quốc Anh.

Journal of Cybersecurity, tập 12, số 1, 2026, tyag020. DOI: https://doi.org/10.1093/cybsec/tyag020. Công bố ngày 16/7/2026.

© Các tác giả 2026. Bản gốc được Oxford University Press phát hành theo CC BY 4.0: https://creativecommons.org/licenses/by/4.0/. Bản tiếng Việt này là bản chuyển ngữ có sử dụng hỗ trợ AI, chưa được tác giả gốc hoặc chuyên gia ngôn ngữ thẩm định.

Phạm vi: dịch toàn bộ nội dung nghiên cứu, 12 bảng, 13 chú thích hình, hai phụ lục, các tuyên bố và chú thích cuối trang. Hình gốc được giữ nguyên để đối chiếu; tiêu đề tài liệu tham khảo được giữ bằng ngôn ngữ xuất bản nhằm thuận tiện tra cứu. Ngôi “chúng tôi” trong phần dịch chỉ các tác giả bài gốc.

Từ khóa: phishing, smishing, tội phạm mạng, lừa đảo trực tuyến, tên miền độc hại.

## Ghi chú biên dịch và đối chiếu

- Đối chiếu phạm vi dự án: đây là bài báo gốc về tên miền, không phải nghiên cứu bộ phân loại email EML. Thực nghiệm Enron/SpamAssassin của DT124 sử dụng paper dữ liệu email Champa và cộng sự (2024), DOI 10.1109/ICMI60790.2024.10585821. Việc dịch bài domain không chứng minh đã tái lập thực nghiệm domain.
- Một số số liệu trong bản gốc không nhất quán: phần đóng góp ghi 25,7% tên miền từng được đăng ký, trong khi phần kết quả/Hình 4 ghi 27% và 4.083/15.126. Bản dịch giữ từng số theo vị trí gốc.
- Bảng 3 giữ nguyên nhãn đơn vị % ($10^{-4}$) và số liệu gốc. Tuy nhiên 8.347/36,9 triệu × 100 xấp xỉ 0,0226%, khác nhãn đơn vị công bố; đoạn văn cũng ghi 2,4 trong khi bảng ghi 2,3. Không nên sử dụng bảng để suy ra tỷ lệ chuẩn hóa nếu chưa kiểm tra lại với tác giả.
- Trong phần AS, đoạn văn nêu Amazon 726 nhưng Bảng 7 ghi 736; đoạn văn nêu AS54467 có 236 tên miền, còn dòng gộp AS54467/AS6134 ghi 238. Bản dịch bảo toàn nguồn thay vì tự sửa số liệu.
- Các nhận định về thương hiệu, dịch vụ, chính sách và độ phổ biến phản ánh nghiên cứu gốc/dữ liệu 2023–2024; không mặc định là trạng thái hiện tại. Tên miền minh họa được giữ theo dạng vô hiệu hóa của bài gốc khi có.

## Tóm tắt

Phishing đã phổ biến trong hơn hai thập kỷ và gần đây phát triển thành các hình thức mới như smishing, tức phishing qua SMS. Dù đã tồn tại lâu, hình thức này vẫn là mối đe dọa đáng kể, lừa đảo nạn nhân trên toàn cầu. Tội phạm mạng xâm nhập các website lành tính hoặc đăng ký tên miền mới để lưu trữ trang phishing. Các trang này mạo danh thương hiệu và dụ nạn nhân cung cấp thông tin cá nhân hoặc tài chính. Hạ tầng bị lợi dụng trong trường hợp website lành tính bị xâm nhập khác với hạ tầng của tên miền mới đăng ký, do đó cần những biện pháp giảm thiểu khác nhau. Trong bài báo này, chúng tôi nghiên cứu các tên miền mới mà tội phạm mạng đăng ký chỉ nhằm lưu trữ website phishing. Chúng tôi phân tích 15.126 tên miền mới đăng ký duy nhất trong 11 tháng. Các tên miền này có thời gian tồn tại trung bình 8,6 ngày; kẻ xấu cũng đăng ký lại các tên miền cũ để sử dụng cho phishing. Hạ tầng bên thứ ba mà chúng lợi dụng khác đáng kể so với nơi tập trung website bị xâm nhập hoặc quần thể website nói chung. Kết quả giúp xác định những nơi có thể tập trung nỗ lực để gỡ bỏ tên miền đăng ký độc hại nhanh hơn, từ một hệ thống tự trị tương đối mới đến cơ quan quản lý đăng ký .COM và các nhà đăng ký cho phép mức ẩn danh cao hơn. Nhà đăng ký cần giám sát tên miền mới để nhận diện mẫu hình đăng ký lạm dụng và hạn chế việc bán các tên miền mạo danh tổ chức hợp pháp. Từ kết quả nghiên cứu, chúng tôi đưa ra thêm các khuyến nghị cho những bên liên quan nhằm giảm tác hại của vấn nạn này.


## Giới thiệu

Dù giới học thuật và doanh nghiệp đã thực hiện rất nhiều nghiên cứu, phishing vẫn là một trong những hoạt động tội phạm mạng nổi bật nhất tính đến năm 2023 [1]. Nỗ lực phòng vệ thay đổi theo thời gian để thích ứng với hành vi của kẻ tấn công. Chẳng hạn, nhóm Rock Phish vào giữa những năm 2000 khiến bên phòng vệ tập trung bảo vệ cơ chế ký tự đại diện trong Hệ thống tên miền (DNS). Tương tự, năm 2007 Google triển khai sáng kiến duyệt web an toàn, tích hợp danh sách chặn phishing vào trình duyệt, đơn giản hóa môi trường bảo mật vốn phức tạp đối với người dùng và cho phép chia sẻ thông tin giữa trình duyệt với email. Dù có thể sử dụng kiến thức đã tích lũy, cuộc rượt đuổi liên tục này khiến việc chỉ dựa vào các nghiên cứu trước đây về một môi trường luôn thay đổi trở nên khó khăn.

Một vấn đề cốt lõi và kéo dài đối với kẻ xấu là có được các tên miền phishing mới để sử dụng. Tội phạm mạng có thể xâm nhập website lành tính bằng cách tải thêm nội dung lên website hiện hữu hoặc sửa DNS của tên miền đó để bổ sung đường dẫn đến website của chúng. Qua đó, chúng lưu trữ trang phishing và tận dụng uy tín của website bị xâm nhập để tạo uy tín cho trang phishing. Việc khắc phục các tên miền này cũng có thể khó khăn, vì cách xử lý tốt nhất là giữ lại nội dung hợp pháp, vá lỗ hổng mà kẻ tấn công đã sử dụng và xóa nội dung phishing. Quá trình này có thể tốn kém và mất thời gian.

Cách khác là đăng ký tên miền mới, hoặc đăng ký lại tên miền đã có, chỉ để thực hiện tội phạm mạng. Các tên miền có thể mạo danh thương hiệu cụ thể, dùng chung cho nhiều kiểu mạo danh thương hiệu hoặc được tạo ngẫu nhiên. Mỗi dạng có mục đích riêng: hai dạng đầu có thể đánh lừa những người đọc tên miền nhưng không nhận ra sự giả mạo. Nghiên cứu trước đây cho thấy người dùng thường

không nhận ra những tên miền có tên miền cấp cao nhất (TLD) bất thường, có thêm từ hoặc sử dụng tên miền con [2]. Tội phạm có thể tận dụng điều này bằng nhiều phương pháp chiếm dụng tên miền để đánh lừa người dùng [3–6], hoặc đơn giản sử dụng TLD không đúng [7]. Trang web đối kháng được thiết kế khéo léo có thể đánh lừa nhiều người, kể cả chuyên gia CNTT [8]. Tên miền được tạo ngẫu nhiên hữu ích trong việc vượt qua các hạn chế đăng ký mà một số nhà đăng ký áp dụng để tránh vô tình cấp tên miền cho người dùng độc hại.

Bài báo tập trung vào đăng ký tên miền có mục đích độc hại nhằm thực hiện phishing. Những tên miền này chỉ phục vụ mục đích độc hại nên dễ gỡ bỏ hơn bằng cách liên hệ bên thứ ba liên quan, như nhà đăng ký, nhà cung cấp lưu trữ, thậm chí cơ quan quản lý đăng ký tên miền, hoặc đưa chúng vào danh sách chặn vô thời hạn. Tuy nhiên, cạnh tranh ngày càng tăng giữa các nhà cung cấp DNS và sự sẵn có của các TLD khiến tội phạm dễ đăng ký tên miền hơn. Các dịch vụ DNS bảo vệ cũng sẵn có qua dịch vụ proxy như Cloudflare; website có thể được thiết lập dễ dàng bằng dịch vụ trực tuyến miễn phí như Google Firebase. Điều này làm phức tạp việc chặn tên miền theo địa chỉ IP và cản trở các công ty chuyên gỡ bỏ website xử lý hiệu quả hơn.

Trong khi các công trình trước tập trung vào tên miền bị xâm nhập [9–12], tên miền đăng ký lại [13–16] hoặc phát hiện email/trang web phishing [17–20], nghiên cứu của chúng tôi khảo sát toàn diện các tên miền phishing mới đăng ký do đối tác dữ liệu cung cấp. Những công trình gần đây cùng hướng tập trung vào đăng ký tên miền phishing trên một số TLD cụ thể [21,22], đăng ký lại tên miền độc hại [23–25] hoặc phân biệt tên miền phishing bị xâm nhập với tên miền được đăng ký cho mục đích độc hại [26,27]. Hạ tầng bị lợi dụng để đăng ký độc hại khác đáng kể so với hạ tầng lưu trữ trang phishing trên website bị xâm nhập. Sự đối chiếu này giúp chúng tôi cung cấp thông tin có thể chuyển thành hành động cho các bên thứ ba và chính phủ đang xử lý hạ tầng của bên thứ ba. Phạm vi tập trung đó cũng giúp làm rõ hiện trạng hạ tầng bị lợi dụng để hỗ trợ các trang phishing trên tên miền đăng ký độc hại.

Nghiên cứu khảo sát các tên miền mới đăng ký để trả lời những câu hỏi sau:

1. Tội phạm lợi dụng hạ tầng nào để lưu trữ các tên miền phishing mới đăng ký?
2. Tội phạm mạng mạo danh những thương hiệu nào?
3. Các tên miền này hoạt động trong bao lâu?
4. Các nhà cung cấp chống mã độc phát hiện tên miền phishing mới đăng ký hiệu quả đến đâu?

Bài báo có những đóng góp sau:

1. Chúng tôi khảo sát 15.126 tên miền phishing mới đăng ký trong 11 tháng, chỉ ra cách phân bố những bên thứ ba bị lợi dụng — gồm tổ chức chứng thực (CA), nhà đăng ký, TLD và hệ thống tự trị (AS) — khác với kết quả nghiên cứu website bị xâm nhập hoặc quần thể Internet nói chung.
2. Cụ thể, trong mục Chứng chỉ TLS, chúng tôi phát hiện hơn 79,3% tên miền phishing mới đăng ký được cấp chứng chỉ bảo mật tầng vận chuyển (TLS), so với 66,7% của toàn bộ website phishing [28]. Ngoài ra, 190 tên miền phishing được cấp hơn 50 chứng chỉ TLS kể từ lần đăng ký đầu tiên.

3. Trong mục Các hệ thống tự trị, chúng tôi xác định một AS tương đối mới, chưa đầy hai năm tuổi, được sử dụng để lưu trữ số lượng lớn tên miền phishing mới đăng ký, mặc dù tổng cộng AS này chỉ lưu trữ 17.754 tên miền.

4. Một tỷ lệ đáng kể, 26%, tên miền mới đăng ký lợi dụng Cloudflare; các mức đối chiếu là 33% của toàn bộ website phishing [29], 39% của website smishing [30] và 19% của Internet [31].

5. Kết quả phát hiện của Google Safe Browsing đối với những tên miền mới đăng ký phục vụ phishing không thống nhất giữa các nền tảng, chủ yếu do khác biệt trong cách API và nền tảng web xử lý trường hợp trang phishing chỉ nằm trên tên miền con.

6. Tên miền phishing mới đăng ký hoạt động trung bình 8,6 ngày, so với 21 giờ của một chiến dịch phishing trung bình [32]. Chúng tôi còn nhận thấy 25,7% mẫu là các tên miền từng được đăng ký trước đây; phần lớn áp đảo trong số này ban đầu cũng được đăng ký để thực hiện tội phạm mạng.

# Kiến thức nền

Phần này cung cấp kiến thức nền cần thiết. Trước hết, chúng tôi giới thiệu ngắn gọn các bên chính trong hệ sinh thái tên miền. Sau đó, chúng tôi giải thích cách tội phạm thực hiện phishing và smishing thông qua website đã được lưu trữ nhưng bị xâm nhập và thông qua tên miền mới đăng ký. Cuối cùng, chúng tôi thảo luận lựa chọn của kẻ tấn công và ý nghĩa của những lựa chọn đó đối với bên thứ ba bị lợi dụng.

## Hệ sinh thái tên miền

Tội phạm xâm nhập website đã được lưu trữ hoặc đăng ký tên miền mới để thực hiện phishing và smishing. Trong cả hai trường hợp, dịch vụ của bên thứ ba bị lợi dụng để lưu trữ trang phishing. Tuy nhiên, tùy tình huống, bên thứ ba có thể tương tác hoặc không tương tác với tội phạm, từ đó thực hiện các hành động cần thiết khác nhau. Vì vậy, cần hiểu các bên chính cùng vai trò của họ trong hệ sinh thái đăng ký tên miền.

### ICANN

Tổ chức Quản lý tên miền và số hiệu Internet (ICANN) là tổ chức phi lợi nhuận điều phối hệ thống định danh duy nhất của Internet toàn cầu, gồm địa chỉ số và tên miền [33]. ICANN chịu trách nhiệm đưa vào các TLD mới và, ngoại trừ TLD mã quốc gia, ký hợp đồng với cơ quan quản lý đăng ký cũng như công nhận nhà đăng ký.

### Cơ quan quản lý đăng ký (registry)

Cơ quan quản lý đăng ký vận hành từng TLD và duy trì tệp vùng liệt kê tất cả tên miền cùng máy chủ tên có thẩm quyền của chúng bằng cơ chế Rapid Zone Update. IANA phân loại TLD thành sáu nhóm; phổ biến nhất là TLD dùng chung (gTLD) và TLD mã quốc gia (ccTLD) [34]. Đơn vị muốn vận hành gTLD phải được ICANN phê duyệt và tuân thủ chính sách của tổ chức này; ngược lại, ảnh hưởng của

ICANN đối với ccTLD như .uk hoặc .ca thấp hơn đáng kể. Một số cơ quan, chẳng hạn cơ quan quốc gia, chủ động phát hiện lạm dụng trên TLD của mình và phối hợp với nhà đăng ký liên quan để gỡ bỏ tên miền [35].

### Nhà đăng ký tên miền (registrar)

Nhà đăng ký bán tên miền cho người đăng ký. Để bán tên miền thuộc một TLD cụ thể, họ phải được ICANN hoặc cơ quan quản lý ccTLD tương ứng công nhận. Ví dụ, IONOS đăng ký với Nominet, cơ quan quản lý ccTLD .uk, nên có thể bán tên miền .uk cho người dùng. Trách nhiệm chính của nhà đăng ký là duy trì hồ sơ đăng ký, gồm thông tin liên hệ người đăng ký và máy chủ tên có thẩm quyền gắn với tên miền. ICANN cung cấp danh sách hơn 2.000 nhà đăng ký được công nhận quản lý dịch vụ đăng ký gTLD [chú thích 1].

Thỏa thuận Công nhận nhà đăng ký năm 2013 yêu cầu các nhà đăng ký được ICANN công nhận cung cấp thông tin liên hệ tiếp nhận lạm dụng và thực hiện điều tra các báo cáo lạm dụng. Nhờ đó, nhà đăng ký có quyền thực hiện những bước hợp lý, kịp thời để điều tra và phản hồi phù hợp, gồm hủy đăng ký tên miền theo kết quả điều tra [36].

### Hệ thống tự trị (AS)

Hệ thống tự trị là một nhóm mạng lớn có chính sách định tuyến thống nhất, phục vụ một tập tiền tố IP. Nhiều AS đồng thời là nhà cung cấp lưu trữ, cung cấp máy chủ lưu và phân phối nội dung. AS được kỳ vọng thẩm tra trước khi cung cấp dịch vụ và chủ động xử lý lạm dụng trên mạng của mình. Họ có quyền gỡ bỏ nội dung có hại được lưu trên mạng để ngăn người dùng truy cập. Tương tự nhà đăng ký, họ cần có đầu mối để bên phòng vệ báo cáo phishing và nhanh chóng điều tra báo cáo nhằm thực hiện hành động cần thiết [37].

### Tổ chức chứng thực (CA)

CA lưu trữ, ký và cấp chứng chỉ số cho website để xác thực tên miền. Giao thức TLS dùng các chứng chỉ này để xác minh danh tính và cung cấp liên lạc mã hóa. Đối với tên miền được đăng ký có mục đích độc hại, CA có thể phát hiện lạm dụng khi tội phạm yêu cầu cấp chứng chỉ TLS cho tên miền mới để lưu trữ trang phishing. CA có thể sử dụng lịch sử lạm dụng của tên miền trước khi cấp chứng chỉ và có quyền thu hồi chứng chỉ khi xác nhận lạm dụng.

## Website bị xâm nhập

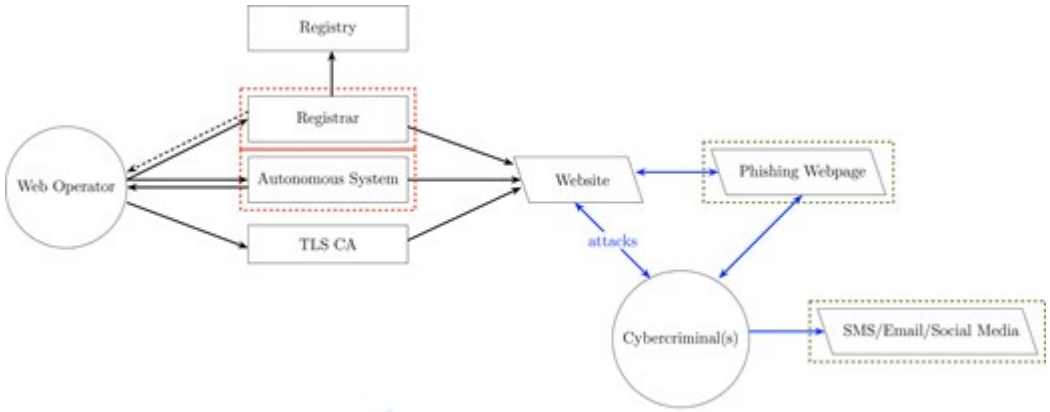
Tội phạm dựng trang phishing bằng cách tìm và khai thác lỗ hổng trên website hiện hữu để giành quyền truy cập, sau đó lưu trữ trang mạo danh thương hiệu quen thuộc [9,10,38]. Các trang phishing thường được tải vào một thư mục tách biệt với phần còn lại của website nhằm tránh phát hiện và tránh vô tình ảnh hưởng hoạt động website. Tội phạm liên kết đến trang phishing đã tải lên bằng URL đầy đủ, vốn thường dài. Chẳng hạn, hxxps://talofdrag[.]tempurl[.]host/wp-admin/net/auth/autorisatioss/f9a015b70637e871832a0b3f585d9274/ lưu trữ trang phishing trên một website bị xâm nhập, mạo danh thương hiệu giải trí nổi tiếng Netflix [chú thích 2].

### Kênh bị lợi dụng

Email cho phép tội phạm che giấu đường dẫn đầy đủ của trang phishing trên website bị xâm nhập bằng văn bản hoặc nút chứa siêu liên kết. Hình A1 trong phụ lục minh họa cách chúng che đường dẫn đầy đủ bằng một nút siêu liên kết trong email.

### Hạ tầng

Tội phạm xâm nhập website vô tội để lưu trữ trang phishing. Các trang này tận dụng uy tín tên miền và hạ tầng sẵn có để duy trì tấn công. Chúng không phải liên lạc trực tiếp với nhà đăng ký, AS hay CA để lưu trữ nội dung. Dù không phải trả chi phí hạ tầng khi xâm nhập website hợp pháp, hành vi này đôi khi khiến chủ tên miền hợp pháp phải chịu chi phí cao hơn, như chi phí dọn dẹp và tổn thất uy tín. Tuy nhiên, tội phạm cần kỹ năng kỹ thuật để tìm và khai thác lỗ hổng; đôi khi chúng thuê người khác khai thác trang web thay mình, nên cách này không hoàn toàn miễn phí cho kẻ tấn công. Hình 1 thể hiện tương tác của tội phạm với website hợp pháp để lưu trữ trang phishing. Trong đa số trường hợp, nhà cung cấp dịch vụ cũng không biết trang phishing đang lợi dụng dịch vụ của họ trên tên miền hợp pháp, trừ khi nhận báo cáo hoặc website được giám sát chủ động.




Hình 1. Đơn vị vận hành website của một tổ chức đăng ký tên miền qua nhà đăng ký, mua dịch vụ lưu trữ từ AS và chứng chỉ TLS từ CA. Tội phạm mạng xâm nhập website hợp pháp để lưu trữ trang phishing, rồi phát tán qua các kênh như email. Đường đen: hoạt động của người dùng và tương tác giữa các bên. Đường xanh lam: hoạt động tội phạm mạng. Ô xanh lá: tín hiệu tình báo để phát hiện phishing. Ô đỏ: bên nhận báo cáo từ tổ chức tình báo mối đe dọa.

### Nhận diện

Website hợp pháp thường không được giám sát lạm dụng trừ khi chủ sở hữu trả phí cho dịch vụ này. Bên phòng vệ có thể nhận diện trang phishing trên website bị xâm nhập khi người dùng gắn cờ báo cáo (Hình 1). Sau khi xác nhận, URL được đưa vào danh sách chặn. Vì những website này có mục đích hợp pháp, danh sách chặn URL phải linh hoạt, cho phép gỡ website khỏi danh sách khi nội dung có hại đã được xóa. Đưa tên miền hoặc địa chỉ IP lưu trữ vào danh sách chặn vĩnh viễn sẽ tác động đáng kể đến lưu lượng truy cập, hoạt động kinh doanh và uy tín nhà cung cấp. Dù bên phòng vệ có thể gửi yêu cầu gỡ bỏ, nhà đăng ký không thể đơn giản gỡ một tên miền hợp pháp. Nhà cung cấp lưu trữ cũng không nên ngừng phục vụ mà chưa cố gắng hỗ trợ sửa chữa, vì như vậy là biện pháp quá nặng. Trong trường hợp này, nhà đăng ký và/hoặc nhà cung cấp lưu trữ liên hệ quản trị viên, yêu cầu vá lỗ hổng bị khai thác và xóa nội dung có hại.

## Tên miền được đăng ký với mục đích độc hại

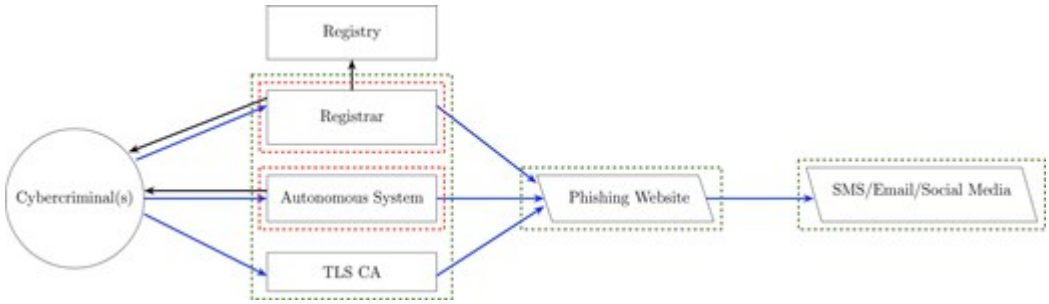
Một số tội phạm thích xâm nhập website, trong khi số khác đăng ký tên miền mới để lưu trữ phishing. Tùy nhóm và nạn nhân mục tiêu, chúng có các chiến lược khác nhau. Chúng thường dùng typosquatting: cố ý đăng ký tên miền là biến thể gõ sai của tên miền thương hiệu nổi tiếng để dựng trang phishing [39–41]. Những tên này dễ bị đọc nhầm hoặc giữ đúng tên nhưng đổi TLD. Không phải mọi tên miền đăng ký độc hại đều có dạng này. Một số chứa từ gắn với nhóm thương hiệu hoặc ngành như giao nhận, ngân hàng. Ví dụ, chúng đăng ký local-courier-id[.]com và support-myevri-locator[.]com để mạo danh công ty giao nhận bưu kiện, rồi gửi đến nạn nhân nhằm dụ cung cấp thông tin cá nhân.

### Kênh bị lợi dụng

Khác email, SMS không cho che URL trong văn bản. Hiển thị nguyên đường dẫn đến trang phishing trên website bị xâm nhập sẽ khiến người dùng nghi ngờ và khó dụ họ nhấp liên kết. Các nhóm tấn công vì vậy thường đăng ký tên miền mới để đánh cắp thông tin cá nhân qua SMS [30,40]. Hình A2 trong phụ lục minh họa việc dùng tên miền mới đăng ký mạo danh ApplePay cho smishing.

### Hạ tầng

Khác trường hợp website bị xâm nhập, ở đây tội phạm đăng ký tên miền, mua dịch vụ lưu trữ và chuẩn bị chứng chỉ TLS chỉ để thực hiện tội phạm mạng: lưu trữ website phishing hoặc phát tán mã độc. Hình 2 minh họa tương tác giữa tội phạm với các bên liên quan.




Hình 2. Tội phạm đăng ký tên miền qua nhà đăng ký, mua dịch vụ lưu trữ từ AS và chứng chỉ TLS từ CA, chỉ nhằm lưu trữ phishing. Những website này bị lợi dụng trong chiến dịch smishing phát tán qua SMS. Đường đen: hoạt động của người dùng và tương tác giữa các bên. Đường xanh lam: hoạt động tội phạm mạng. Ô xanh lá: tín hiệu tình báo để phát hiện phishing. Ô đỏ: bên nhận báo cáo từ các tổ chức tình báo mối đe dọa.

Đăng ký độc hại mang lại một số lợi thế. Thứ nhất, chúng có thể chọn tên miền theo chiến dịch mục tiêu. Một số tên gắn với thương hiệu, như support-myevri-locator[.]com; một số khác liên quan chủ đề smishing và dùng cho nhiều thương hiệu. Ví dụ, local-courier-id[.]com có thể dùng cho mọi chiến dịch smishing liên quan giao hàng hoặc bưu kiện. Thứ hai, chúng có thể chọn AS không chủ động xử lý lạm dụng ngay cả khi được báo cáo, hoặc cố ý hỗ trợ và bảo vệ khách hàng khỏi báo cáo lạm dụng; đó là các nhà cung cấp lưu trữ chống gỡ bỏ, thường đặt tại nước nơi chúng có thể né thực thi pháp luật [42,43]. Website hợp pháp thường sử dụng chứng chỉ TLS để mã hóa giao tiếp giữa máy chủ và website. Để tạo lòng tin, tội phạm cũng sử dụng chứng chỉ TLS do mình lựa chọn cho tên miền mới.

Dịch vụ bên thứ ba miễn phí cũng có thể bị lợi dụng để lưu trữ phishing trên tên miền mới. Ví dụ, Google cung cấp lưu trữ web miễn phí kèm tên miền web.app, như login-auth-device[.]web[.]app. Trong trường hợp này, tội phạm không cần mua tên miền qua nhà đăng ký, mua lưu trữ từ AS hay thậm chí mua chứng chỉ TLS; chúng có thể thiết lập và lưu trang phishing miễn phí.

### Nhận diện

Bên phòng vệ có thể nhắm đến các bên liên quan để gỡ tên miền mới bị lợi dụng cho smishing (Hình 2). So với website bị xâm nhập, tên miền mới bộc lộ nhiều dấu vết hơn: tội phạm đăng ký tên mạo danh thương hiệu, cung cấp thông tin cho nhà đăng ký và lộ diện ngay từ ngày đầu. Bên phòng vệ dùng tệp vùng, địa chỉ IP và chứng chỉ TLS vừa được cấp để phát hiện tên miền mới độc hại. Một số cơ quan quản lý đăng ký cũng giám sát lạm dụng trên TLD của mình và phối hợp nhà đăng ký để gỡ bỏ. Nhiều nhà đăng ký cung cấp dịch vụ tự động đăng ký nhiều biến thể tên miền gõ sai khi chủ nhãn hiệu muốn đăng ký tên miền [39]. Gần đây, các nhà đăng ký hàng đầu còn bán dịch vụ chặn một số kiểu typosquatting để bảo vệ thương hiệu [44].

Cách gỡ bỏ ở đây khác với xóa nội dung trên website bị xâm nhập. Có thể thêm tên miền đăng ký độc hại vào danh sách chặn để ngăn truy cập. Nhà mạng di động còn dùng danh sách này để chặn tin nhắn chứa tên miền. Nhà đăng ký tuân thủ quy định có thể đình chỉ tên miền theo chính sách ICANN và khóa chuyển nhượng để người đăng ký không né biện pháp xử lý rồi tiếp tục sử dụng tên miền [36]. Nhà cung cấp lưu trữ cảnh giác thường xóa nội dung độc hại trong vài giờ kể từ khi phát hiện, qua báo cáo hoặc tự giám sát [45]. Với dịch vụ lưu trữ chống gỡ bỏ, địa chỉ hoặc dải IP có thể bị đưa vào danh sách chặn [43]. Nhà cung cấp còn có thể bị báo cáo hoặc bị các ISP chặn do lạm dụng, qua đó hạn chế khả năng tiếp cận [46].

## Lựa chọn của kẻ tấn công

Một số nhóm đã ưu tiên xâm nhập website để phishing qua email trong gần hai thập kỷ [32,38], nhưng việc đăng ký tên miền độc hại [47] để phishing qua SMS đang tăng [41]. Chúng tôi thảo luận các nguyên nhân ảnh hưởng đến việc ưu tiên phương pháp này hay phương pháp khác.

### Chi phí

Xâm nhập website giúp tiết kiệm chi phí thiết lập hạ tầng vì website đã được lưu trữ sẵn. Tội phạm không phải chịu chi phí hạ tầng để lưu trang phishing, đồng thời tránh tương tác với các bên cung cấp và tránh chia sẻ dữ liệu, chẳng hạn thẻ tín dụng đánh cắp, để mua tên miền hoặc dịch vụ lưu trữ. Tuy nhiên, chúng thường phân công trách nhiệm, trong đó có xâm nhập website, và quá trình đó vẫn có chi phí.

Thiết lập hạ tầng trên tên miền mới tốn tiền. Tuy vậy, tội phạm có thể chọn dịch vụ bên thứ ba miễn phí như Google Firebase để tiết kiệm và hưởng lợi từ uy tín AS. Tên miền gõ sai dùng TLD ít phổ biến cũng không đắt, như Hình A3 cho thấy.

### Uy tín website

Xâm nhập website hợp pháp để lưu trang phishing giúp tội phạm tận dụng uy tín của website đáng tin cậy, vượt bộ lọc bảo mật email và khiến thư phishing có vẻ đáng tin hơn đối với người nhận [48]. Tên miền mới có ít hoặc chưa có uy tín; tên miền đăng ký lại thường kế thừa uy tín cũ. Điều này có thể

làm giảm sức hấp dẫn của tên miền đăng ký độc hại.

### Đánh lừa người dùng

Với website bị xâm nhập, tội phạm che đường dẫn đầy đủ trong email bằng văn bản hoặc nút siêu liên kết, khiến người dùng khó nhận ra phishing. Tên miền mới lại cho phép chọn một tên thuyết phục hơn để dụ nạn nhân. Nhìn chung, nhóm tấn công và đối tượng mục tiêu ảnh hưởng đến chiến lược lưu trang phishing. Ví dụ, kẻ thực hiện smishing thường chọn tên miền ngắn hơn [30] và có vẻ thuyết phục hơn, như pay-ap[.]com để mạo danh Apple Pay.

### Khả năng duy trì lưu trữ

Tội phạm từng ưu tiên xâm nhập website [9]. Một số chiến lược phòng vệ dùng tệp vùng đăng ký hoặc chứng chỉ TLS được cấp theo thời gian thực để nhận diện tên miền độc hại; số khác giám sát website có lỗ hổng đã biết [10,49]. Giám sát định kỳ có thể giúp vá website trước khi bị xâm nhập [50], nhưng đa số AS không phát hiện được hoạt động độc hại trên website [51]. Tội phạm được lợi vì không phải thương hiệu nhỏ nào cũng trả tiền giám sát và không phải AS nào cũng chủ động phát hiện website bị xâm nhập. Bên phòng vệ có thể giảm thiểu bằng cách gửi báo cáo phishing đúng nơi. Tuy nhiên, khi tên miền đăng ký hợp pháp bị xâm nhập, nhà đăng ký hoặc cơ quan quản lý đăng ký không gỡ ngay. Họ có thể liên hệ trực tiếp nhà cung cấp lưu trữ hoặc quản trị viên và yêu cầu xóa nội dung có hại [37]. Tùy đơn vị cung cấp, xử lý báo cáo có thể mất thời gian, cho tội phạm thêm cơ hội đánh lừa nạn nhân.

Với tên miền mới, tội phạm có thể chọn nhà đăng ký và AS ít chủ động gỡ bỏ hoặc hỗ trợ lạm dụng. Một số nhóm thậm chí chọn dịch vụ lưu trữ chống gỡ bỏ, hỗ trợ hành vi xấu và đặt tại quốc gia nơi lực lượng thực thi khó hành động chủ động. Thông tin liên hệ công khai, có thể xử lý tự động mà tội phạm khai cho trang trên tên miền mới phần lớn không chính xác [52]. Nhờ đó chúng có thêm thời gian. Nhà cung cấp tốt có thể cố liên hệ họ để điều tra khiếu nại trước khi áp dụng biện pháp mạnh hơn như gỡ bỏ.

### Tính sẵn có

Tội phạm tìm website dễ bị tấn công trên Internet và có thể xâm nhập lại cùng website để lưu phishing [9,53]. Tùy kênh lạm dụng, chẳng hạn smishing, chúng mua tên miền mới hoặc đăng ký lại tên miền độc hại từng bị gỡ [14,16]. Một số khác theo dõi và đăng ký tên miền hợp pháp ngay khi tên hết hạn hoặc tổ chức đóng cửa [13].

### Né phát hiện

Điện thoại thông minh thiếu các bộ lọc bảo mật tinh vi bảo vệ tài khoản email nên kẻ gian dễ tiếp cận nạn nhân hơn [54]. Email có thêm siêu dữ liệu thường được dùng để nhận diện phishing, trong khi SMS thiếu chúng. Để né phát hiện, tội phạm dùng kỹ thuật như giới hạn truy cập theo địa lý [55,56]. Chúng nhắm nạn nhân theo quốc gia, điều tương đối dễ xác định trong lừa đảo qua điện thoại, và cấu hình website chỉ cho người dùng ở quốc gia mục tiêu truy cập URL. Nhờ vậy, hệ thống tự động của bên phòng vệ đặt tại vùng khác khó phát hiện hơn. Chúng cũng có thể hạn chế theo loại thiết bị: trang smishing thường chỉ hiển thị trên điện thoại, không hiển thị trên máy tính. Đôi khi, trang chuyển hướng tải mã độc Android khi mở bằng điện thoại Android nhưng hiển thị phishing trên máy tính. Website bị xâm nhập cũng có thể dùng các kỹ thuật này, song chúng phổ biến hơn ở tên miền đăng ký độc hại.

## Sự cần thiết nghiên cứu tên miền đăng ký độc hại

Phishing qua SMS, hay smishing, gần đây gia tăng [54,57–59]. Trang phishing trên website bị xâm nhập có đường dẫn dài, không có vẻ mạo danh và không thể được che trong SMS. Vì vậy, để dụ nạn nhân hành động, kẻ gian phải đăng ký tên miền độc hại giống thương hiệu [40]. Khi nhiều tổ chức nhà nước và tư nhân dùng SMS để giao tiếp và cập nhật cho người dùng, tội phạm cũng tăng lợi dụng kênh này để mạo danh bằng tên miền đăng ký độc hại. Ví dụ, chúng tận dụng việc dịch vụ gửi tin nhắn về phí sử dụng đường thu phí. Báo cáo ghi nhận nhiều tên miền bị lợi dụng tại Mỹ, Australia và Ireland cho chiến dịch smishing phí đường bộ [41,60,61]. Điều đó cho thấy tên miền đăng ký độc hại đang tăng và là vấn đề nghiên cứu quan trọng.

### Trách nhiệm của dịch vụ bên thứ ba bị lợi dụng

Dù tội phạm lợi dụng bên thứ ba để đăng ký và lưu trang phishing, tiếp tục cung cấp dịch vụ sau khi biết có lạm dụng cho thấy sự hỗ trợ đối với tội phạm. Dịch vụ đầu tư phát hiện tên miền đăng ký độc hại, phản hồi nhanh thông báo và hợp tác với tổ chức tình báo mối đe dọa có thể được xem là thực hiện nghĩa vụ, ngay cả khi một số tên miền lọt qua. Ngược lại, đơn vị không thực hiện bảo vệ cơ bản hoặc phớt lờ báo cáo có thể bị xem là tạo điều kiện. Hạ tầng bị lợi dụng khi xâm nhập website hợp pháp khác với hạ tầng của tên miền đăng ký độc hại, nên cách gỡ bỏ cũng khác. AS lưu website hợp pháp bị xâm nhập trở thành nạn nhân gián tiếp; AS lưu tên miền đăng ký độc hại có thể thông đồng với tội phạm để hỗ trợ hoạt động bất hợp pháp.

### Tổng hợp

Khi lừa đảo SMS gia tăng, việc kẻ tấn công phụ thuộc vào tên miền đăng ký độc hại cho thấy chúng đầu tư nhiều hơn vào hạ tầng chiến dịch smishing. Điều này phản ánh môi trường đang biến đổi và cách chúng điều chỉnh phương pháp theo đặc điểm kênh bị lợi dụng. Chúng chọn cách phù hợp nhất để khai thác điểm yếu và hành vi người dùng trên kênh mục tiêu. Hạ tầng và thủ đoạn chuyên nhắm người dùng điện thoại thông minh vì vậy có thể tiếp tục tăng, đặt ra yêu cầu phòng vệ tốt hơn.

Đa số nghiên cứu hạ tầng trước đây dùng nguồn tổng hợp chứa website hỗn hợp chưa gắn nhãn phân biệt [28,32,38,62]; cần hiểu hệ quả của điều đó đối với xử lý lạm dụng. Phân bố TLD hoặc nhà đăng ký của website bị xâm nhập chủ yếu cho biết tên miền nào bị nhắm đến, hơn là thực hành bảo mật của hạ tầng. Ngược lại, phân bố nhà đăng ký của tên miền đăng ký độc hại chỉ ra nhà cung cấp bị lợi dụng hoặc đang dung dưỡng tội phạm. Sức hấp dẫn của họ có thể đến từ giá thấp, sàng lọc thiếu chặt chẽ hoặc thuận tiện cho tội phạm. Hiểu biết này giúp các tổ chức ngành xây dựng hướng dẫn thực hành tốt để xử lý hiệu quả tên miền đăng ký độc hại. Nó cũng thúc đẩy đơn vị tổng hợp và bên phòng vệ gắn nhãn đúng URL phishing để xử lý nhanh, đồng thời hỗ trợ chính phủ xây dựng chính sách ngăn đăng ký tên miền độc hại.

Phần Công trình liên quan tiếp theo làm rõ điểm mới của nghiên cứu, tập trung vào tên miền đăng ký độc hại. Phần Phương pháp mô tả cách thu thập và làm giàu dữ liệu tên miền mới bị lợi dụng cho phishing. Phân tích dữ liệu đã làm giàu, phần Kết quả trình bày hiểu biết về hạ tầng tội phạm khai thác để đăng ký và lưu trang phishing. Cuối cùng, phần Thảo luận bàn về phát hiện và đề xuất biện pháp giảm thiểu.

# Công trình liên quan

Chúng tôi xem xét khối lượng nghiên cứu phishing lớn, phân chia theo nguồn dữ liệu URL phishing. Một số chỉ xét website bị xâm nhập, số khác chỉ xét tên miền đăng ký độc hại, nhưng phần lớn dùng nguồn trộn cả hai. Điều đó làm suy yếu các biện pháp can thiệp được tác giả đề xuất.

## Website bị xâm nhập

Tội phạm khai thác lỗ hổng website hợp pháp để lưu trang phishing. Trong hơn một thập kỷ, đây là cách phổ biến nhất. Chúng xâm nhập rồi tái xâm nhập máy để lưu website phishing [9]. Máy chủ web chạy hệ quản trị nội dung như WordPress dễ bị lợi dụng hơn [10,11]; sự đồng nhất này tạo môi trường mục tiêu thuận lợi. Khi tấn công trên website lành tính bị xâm nhập, tội phạm hưởng lợi từ uy tín tốt của website. So với thiết lập tên miền mới, chúng có thể tiết kiệm thời gian và tiền.

Tuy nhiên, cần hiểu khác biệt vì nơi nhận báo cáo và hành động gỡ nội dung độc hại thay đổi đáng kể theo mục đích website. Nếu nhiều website bị xâm nhập, cần cung cấp dịch vụ dọn dẹp và lựa chọn lưu trữ an toàn hơn cho quản trị viên. Nếu nhiều tên miền được đăng ký độc hại, cần cấp thêm nguồn lực cho đơn vị vận hành hạ tầng để ngăn việc đăng ký và lưu nội dung độc hại ngay từ đầu. Phân tích dự báo [49] có thể giúp giảm website bị xâm nhập.

Cấu trúc URL phishing trên website bị xâm nhập rất đa dạng: địa chỉ IP làm hostname, tên miền ngẫu nhiên kèm đường dẫn đánh lừa, tên miền con dài đánh lừa hoặc tên miền ngẫu nhiên khó hiểu [11,12]. Oest và cộng sự [11] giả thuyết rằng nhóm URL đại diện hạ tầng bị xâm nhập và nhóm do kẻ phishing triển khai ít chồng lấn, nhưng chưa kiểm chứng. Những người khác đề xuất phát hiện trang phishing bị xâm nhập dựa trên mẫu chuỗi con URL [50], khác biệt hình ảnh với những trang khác cùng website [48] hoặc nhật ký mạng [51].

## Tên miền đăng ký độc hại

Tên miền đăng ký độc hại thường có tên đánh lừa để dụ nạn nhân dễ hơn so với website bị xâm nhập hoặc URL rút gọn [12,63]. Typosquatting là cách phổ biến: kẻ lừa đảo đăng ký biến thể gõ sai của tên miền nổi tiếng để dụ người dùng nhấp URL phishing [3,5,39]. Khác email, URL phishing không thể được che trong SMS; để dụ nạn nhân, tội phạm phải dùng tên miền đánh lừa mạo danh thương hiệu mục tiêu [11,30,64].

Domain tasting là khoảng ân hạn năm ngày để đăng ký thử tên miền; sau thời gian này, phí đăng ký không được hoàn lại [65]. Năm 2008, McGrath và Gupta [12] nhận thấy đối thủ cũng lợi dụng tính năng này: 6,1% tên miền bị bỏ trong giai đoạn ân hạn. Vài năm sau, Coull và cộng sự [66] xác định 76% lượt đăng ký khác nhau trong toàn bộ dữ liệu VeriSign là hệ quả của domain tasting. Dù kẻ xấu từng lợi dụng cơ chế này, nghiên cứu của chúng tôi cho thấy thời gian tồn tại trung bình của tên miền mới hiện dài hơn khoảng ân hạn năm ngày.

### Lạm dụng TLD cụ thể

Một số nhóm lợi dụng TLD cụ thể để đăng ký tên miền mới, đôi khi lạm dụng TLD vừa công bố nhiều hơn TLD cũ. Halvorson và cộng sự [21] nhận thấy trong tháng đầu đăng ký, tên miền thuộc gTLD mới có khả năng xuất hiện trong danh sách chặn cao hơn gấp đôi TLD lâu đời. Nghiên cứu ccTLD .eu, Vissers và cộng sự [22] quan sát thấy 80% đăng ký độc hại thuộc 20 chiến dịch kéo dài, và 18% không bao giờ xuất hiện trong danh sách chặn nào.

### Lạm dụng hạ tầng khác

Tùy nhóm, tội phạm có thể mua máy chủ web mới giá rẻ, thuê từ nhóm khác hoặc lưu trên hạ tầng botnet sẵn có [67]. Nhà cung cấp lưu trữ chống gỡ bỏ và ẩn danh cho phép lưu website phishing, thậm chí chủ động báo trước vài ngày khi nhận báo cáo để khách chuyển sang dịch vụ khác [42]. Họ thường đăng ký tại nước nơi cơ quan thực thi khó tiếp cận, khiến gỡ bỏ khó khăn. Từ năm 2011, nghiên cứu đã tìm ra các nhóm TLD [62], nhà đăng ký [14,62,68] và nhà cung cấp lưu trữ [14,62,69] bị lợi dụng cho đăng ký và lưu tên miền độc hại, nhưng hệ sinh thái đã thay đổi. Hơn nữa, mỗi dự án khảo sát nhóm đơn vị vận hành khác nhau cho các mục tiêu khác, thay vì phân tích toàn diện nhiều đơn vị nhất có thể để đề xuất chiến lược giảm thiểu tên miền độc hại.

### Phát hiện tên miền độc hại

Nghiên cứu trước dùng học máy với kỳ vọng phát hiện tên miền độc hại sớm trong vòng đời, ngay khi đăng ký hoặc thậm chí trước đó [20,69–76]. Nghiên cứu của chúng tôi có thể giúp cải thiện thuật toán bằng hiểu biết về sự thay đổi mức tập trung của chúng trên các đơn vị hạ tầng.

### Tên miền đăng ký lại

Các nghiên cứu phát hiện tội phạm thường tái sử dụng hoặc đăng ký lại tên miền do chúng hoặc người khác từng đăng ký [14–16,23]. Moore và Clayton [13] tìm thấy hiện tượng đăng ký lại tên miền ngân hàng sau khi ngân hàng đóng cửa, lợi dụng uy tín cũ cho hoạt động bất hợp pháp. Miramirkhani và cộng sự [24] nghiên cứu cách chọn tên miền để đăng ký lại. Lauinger và cộng sự [77] nghiên cứu dịch vụ drop-catch cạnh tranh đăng ký lại tên miền. Ở công trình tiếp nối, họ thấy đa số đăng ký lại diễn ra sớm nhất có thể và các tên miền đã xóa được đăng ký lại hàng loạt vài giờ sau [25]. Đối tượng độc hại thường xóa tên miền trước hạn, cho phép đăng ký lại và tiếp tục lạm dụng [68].

### Tấn công được hỗ trợ bởi đăng ký lại tên miền

Website phổ biến có thể nhúng JavaScript từ xa trỏ đến tên miền hết hạn. Nikiforakis và cộng sự [78] chỉ ra rằng đăng ký lại những tên miền đó cho phép chèn mã. Vissers và cộng sự [79] chứng minh đăng ký lại tên miền hết hạn có thể chiếm quyền hàng nghìn tên miền qua máy chủ tên lỗi thời. Tương tự, Schlamp và cộng sự cho thấy có thể chiếm cả một AS bằng cách đăng ký lại tên miền hết hạn [80,81].

Trong khi nghiên cứu đăng ký tên miền độc hại trước đây chủ yếu xét đăng ký lại, chúng tôi nghiên cứu các tên miền mới do tổ chức cộng tác nhận diện là bị lợi dụng để lưu website phishing.

### Website hỗn hợp

Đại đa số nghiên cứu phishing trước sử dụng nguồn dữ liệu ngành, bên tổng hợp hoặc diễn đàn trực tuyến như Twitter [10–12,38,82–87]. Nguồn tổng hợp chủ yếu chứa website bị xâm nhập và không phân biệt chúng với tên miền đăng ký độc hại. Vì vậy, khó phân biệt hạ tầng bị lợi dụng ở hai trường hợp, làm khó việc gỡ bỏ và tạo ra hiểu biết hỗ trợ gỡ bỏ. Nhiều người có thể truy cập dữ liệu bên tổng hợp; chúng tôi lưu ý từ trước đến nay mức chồng lấn giữa họ và công ty chuyên gỡ bỏ là đáng kể [88].

#### Chứng chỉ TLS bị lợi dụng cho phishing

Bijmans và cộng sự [62] nhận thấy kẻ gian dùng nhiều chứng chỉ TLS cho website phishing. CA cấp chứng chỉ để bảo mật liên lạc website nhưng phần lớn chứng chỉ đã cấp cho website phishing không bị thu hồi [62]. Borgolte và cộng sự [89] đề xuất phương pháp xác thực tên miền dựa trên độ tin cậy, đưa uy tín sẵn có của tên vào quy trình. Kim và cộng sự [28] nghiên cứu lạm dụng chứng chỉ TLS trong dữ liệu tổng hợp chủ yếu chứa website bị xâm nhập. Nghiên cứu của chúng tôi là công trình đầu tiên làm rõ việc lợi dụng chứng chỉ TLS ở tên miền phishing mới đăng ký có chủ đích độc hại.

#### Gỡ bỏ phishing

Gỡ bỏ phishing chủ yếu tập trung vào địa chỉ IP hoặc tên miền chứa nội dung độc hại. Nghiên cứu trước thấy website không thuộc Rock-Phish bị gỡ sớm hơn và gỡ địa chỉ IP chậm hơn gỡ tên miền [38]. Kẻ gian tận dụng điều này, triển khai nhiều địa chỉ IP và tên miền để website tiếp tục hoạt động. Rock-Phish và các cuộc tấn công fast-flux dùng nhiều IP và tự động thay thế chúng để duy trì website [12,38], kéo dài tuổi thọ. Fast-flux là mối đe dọa phishing lớn, tiếp tục phát spam cho nhiều website tồn tại lâu cho đến khi bị xóa [90]. Một số nhà cung cấp gỡ nhanh hơn đơn vị khác; một số thương hiệu cũng được gỡ trang giả nhanh hơn [45]. So với cơ quan thực thi pháp luật, công ty chuyên bảo vệ thương hiệu gỡ website phishing hiệu quả hơn [91].

#### Phát hiện và phân loại phishing

Nghiên cứu trước đưa ra nhiều phương pháp phát hiện tên miền phishing hoặc độc hại nói chung [17–20]. Một số xây mô hình phân loại để phân biệt tên miền bị xâm nhập với tên miền mới [26,27]. Chúng tôi phân tích thực nghiệm tên miền mới trên quy mô lớn, cung cấp hiểu biết có thể cải thiện những cách phát hiện đó.

Công trình khảo sát theo thời gian thực hơn 15 nghìn tên miền mới do đối tác cung cấp, làm rõ hạ tầng mà tội phạm lợi dụng để đăng ký và thực hiện phishing cũng như thay đổi so với các nghiên cứu trước. Chúng tôi ủng hộ yêu cầu phân biệt tên miền bị xâm nhập với tên miền phishing mới đăng ký vì chiến lược giảm thiểu khác đáng kể.

## Phương pháp

Phần này mô tả những tập dữ liệu dùng để nghiên cứu tên miền mới bị lợi dụng cho phishing và cách làm giàu dữ liệu để trả lời các câu hỏi nêu trong phần Giới thiệu.

## Các tập dữ liệu

### Tên miền mới đăng ký

Chúng tôi hợp tác với Cyber Defence Alliance, tổ chức tình báo mối đe dọa quốc tế phi lợi nhuận hoạt động theo thành viên, cung cấp hằng ngày các tên miền đầy đủ (FQDN) được nhận diện là độc hại từ ngày 5/7/2023 đến 23/5/2024. Bảng 1 tổng quan dữ liệu thu thập và các thông tin làm giàu.

**Bảng 1. Tổng hợp dữ liệu thu thập và làm giàu cho các tên miền đăng ký độc hại.**

| FQDNs | Tên miền | Thu thập dữ liệu | CA TLS | TLDs | Nhà đăng ký | Hệ thống tự trị | Thương hiệu |
|---|---|---|---|---|---|---|---|
| | | | | | | Mã AS (ASN) | |
| 15 975 | 15 126 | 5/7/2023–23/5/2024 | 34 | 190 | 209 | 395 | 58 |

Đối tác là liên minh nhiều ngân hàng quốc tế có sự hỗ trợ của lực lượng thực thi pháp luật. Họ nhận diện tên miền mới mạo danh khách hàng và tên miền chung nhắm ngành cụ thể, như công ty giao nhận, hoặc chủ đề như người nhận thanh toán mới. Các tên miền này không bao gồm URL rút gọn; tổ chức cũng nhận dữ liệu tên miền bổ sung không theo lịch cố định từ thành viên. Họ sử dụng nhiều nguồn săn tìm mối đe dọa, như kiểm tra chứng chỉ TLS được cấp theo thời gian thực. Nguồn dữ liệu bao gồm mọi tên miền họ nhận diện mỗi ngày có liên quan chiến dịch smishing/phishing đang diễn ra hoặc sắp diễn ra. Tổ chức tài chính và nhà mạng di động tiếp nhận nguồn hằng ngày để gỡ bỏ và chặn SMS chứa tên miền độc hại.

### Website hỗn hợp, chủ yếu bị xâm nhập

Chúng tôi truy cập các giá trị tổng hợp về URL phishing trong kho eCrime Exchange (eCX) của Anti-Phishing Working Group (APWG), từ tháng 7/2023 đến tháng 5/2024 [92]. Bảng 2 cho biết số tên miền đăng ký độc hại nhận từ đối tác mỗi tháng và tổng số tên miền APWG eCX thu thập cùng kỳ.

**Bảng 2. Phân bố theo tháng của tên miền đăng ký độc hại (n = 15.975) nhận từ tổ chức tình báo trong khoảng 5/7/2023–23/5/2024 và tên miền (n = 191.923) do APWG eCX [92] phát hiện cùng kỳ. Có 849 tên miền trong dữ liệu của chúng tôi và 32.053 tên miền trong dữ liệu APWG eCX xuất hiện nhiều hơn một lần.**

| Tháng | Tên miền | |
|---|---|---|
| | Đăng ký độc hại | Website hỗn hợp |
| | (Dữ liệu nghiên cứu) | (APWG eCX) |
| 07/2023 | 983 | 19 847 |
| 08/2023 | 1601 | 23 325 |
| 09/2023 | 1892 | 22 327 |
| 10/2023 | 1633 | 24 478 |
| 11/2023 | 1270 | 20 338 |
| 12/2023 | 1293 | 16 085 |
| 01/2024 | 1679 | 15 360 |
| 02/2024 | 1464 | 8548 |
| 03/2024 | 1233 | 12 843 |
| 04/2024 | 1632 | 12 229 |
| 05/2024 | 1295 | 16 543 |

APWG là tổ chức thành viên vận hành kho tập trung trao đổi dữ liệu Internet và sự kiện máy về tội phạm mạng như phishing. Thành viên gồm thương hiệu, doanh nghiệp, tổ chức phi chính phủ và tổ chức học thuật đóng góp dữ liệu vào eCX. Kho chứa URL mới được báo cáo hằng ngày, thương hiệu bị nhắm đến nếu có và điểm tin cậy. Dù APWG eCX bao phủ tên miền ở quy mô lớn hơn, nó không phân biệt tên miền mới đăng ký với tên miền bị xâm nhập, nên không thể trực tiếp trả lời câu hỏi của nghiên cứu này.

## Làm giàu dữ liệu

Chúng tôi làm giàu nguồn dữ liệu tên miền đăng ký độc hại hằng ngày để trả lời RQ1–RQ4 bằng nhiều công cụ dòng lệnh và dịch vụ bên thứ ba, được trình bày dưới đây.

### Nhà đăng ký tên miền

Nhà cung cấp dữ liệu thu thập thông tin đăng ký ngay khi nhận diện tên miền phishing mới. Chúng tôi bổ sung và kiểm tra độ chính xác bằng lệnh whois chạy cục bộ đối với tên miền còn thiếu và một số tên miền đã biết. Lệnh whois cung cấp chi tiết tên miền, gồm nhà đăng ký [93].

### Địa chỉ IP

Ngay khi nhận nguồn hằng ngày, chúng tôi dùng lệnh dig [chú thích 3] để tìm IP tương ứng từng tên miền. IP thường được xem là tương ứng duy nhất với một nhà cung cấp lưu trữ, đơn vị cho tên miền thuê máy chủ và định tuyến lưu lượng vào/ra. Tuy nhiên, không phải mọi IP trong mẫu đều chỉ đến nhà cung cấp lưu trữ: 31,7% không thể định tuyến do IP không tồn tại hoặc không có phản hồi; ít nhất

17,7% là dịch vụ proxy. Proxy đứng giữa nhà cung cấp lưu trữ và người truy cập, có nhiều mục đích hợp pháp như truy cập nhanh trên toàn cầu và chống từ chối dịch vụ. Tuy nhiên, khi phục vụ website tội phạm mạng, chúng còn che giấu nhà cung cấp lưu trữ phía sau.

### Hệ thống tự trị

Với mỗi IP, chúng tôi truy vấn ipinfo.io [94] và công cụ tra ASN dòng lệnh của Cymru [95] để biết AS sở hữu. Truy vấn được thực hiện theo thời gian thực khi nhận nguồn hằng ngày. Dải IP thay đổi thường xuyên nên tính kịp thời rất quan trọng.

### Chứng chỉ TLS

Sectigo, nhà cung cấp giải pháp quản lý chứng chỉ, vận hành crt.sh, cơ sở dữ liệu mọi chứng chỉ TLS được cấp cho tên miền. Chúng tôi truy vấn API crt.sh [96] cho từng tên miền ngay khi nhận, thu được toàn bộ chứng chỉ từng cấp cho tên miền trong dữ liệu cùng CA phát hành.

### DNS thụ động

DNS thụ động ghi nhật ký lưu lượng DNS trên Internet để cung cấp lịch sử các IP mà tên miền từng phân giải đến [97]. Chúng tôi dùng API DNS thụ động của Spamhaus [98] để tìm mốc cuối cùng IP được gán cho tên miền và lần đầu Spamhaus quan sát tên miền đó.

### Phát hiện của nhà cung cấp chống mã độc

VirusTotal là dịch vụ tổng hợp hơn 70 bộ quét chống mã độc, cho phép tra cứu tên miền theo thời gian thực và biết bộ quét nào gắn cờ. Chúng tôi dùng API công khai của VirusTotal [99] để thu thông tin theo thời gian thực, bổ sung API Google Safe Browsing [100] cũng theo thời gian thực nhằm quan sát dịch vụ có thể trước khi kết quả của nó được cập nhật trên VirusTotal. Ngoài API, Google cung cấp website Google Transparency Report hiển thị trạng thái bị chặn của website [101]. Chúng tôi tự động kiểm tra trạng thái tên miền trên trang báo cáo đồng thời với truy vấn API để nhận ra sai khác tiềm tàng giữa hai kênh.

## Cân nhắc đạo đức

Đối tác tình báo quốc tế nhận diện và gửi tên miền mới hằng ngày; dữ liệu này không chứa thông tin định danh cá nhân (PII). Phần Các tập dữ liệu giải thích cách họ thu thập có trách nhiệm và phù hợp đạo đức. Chúng tôi cũng không thu PII khi truy vấn whois hoặc các dịch vụ làm giàu khác. Ủy ban đạo đức nghiên cứu của khoa đã xem xét và phê duyệt nghiên cứu.

## Hạn chế

Chúng tôi chỉ hợp tác với một tổ chức tình báo mối đe dọa. Do bí mật kinh doanh, chúng tôi không thể công bố sâu phương pháp nhận diện tên miền mới mạo danh tổ chức. Chúng tôi không kỳ vọng dương tính giả vì hệ thống tự động phát hiện và chuyên viên xác minh thủ công trước khi chia sẻ, nhưng sai sót con người vẫn có thể xảy ra. Các tên miền mạo danh khách hàng của đối tác và một số ngành tài chính, giao nhận. Dữ liệu có thể thiên về khách hàng của họ, tương tự thiên lệch ở bất kỳ nguồn nào khác; chẳng hạn mọi URL phishing liên quan PayPal đều được gửi vào PhishTank, khiến thương hiệu này chiếm ưu thế [102]. Có thể đối tác chưa nhận diện được tất cả tên miền mạo danh

trong những ngành đó; ngay cả dữ liệu tốt nhất cũng thiếu khả năng quan sát đáng kể đối với tên miền tồn tại ngắn [103]. Đây là dạng thiên lệch tương tự những nguồn phishing bên ngoài khác, nhưng vẫn cần lưu ý.

# Kết quả

Chúng tôi trình bày những hiểu biết thu được về các tên miền mới được đăng ký với mục đích độc hại và bị lợi dụng trong các chiến dịch phishing, thường là phishing qua SMS. Bằng phương pháp được xây dựng cẩn thận, chúng tôi trả lời các câu hỏi nghiên cứu nhằm tìm hiểu việc sử dụng và lạm dụng những tên miền được đăng ký với mục đích độc hại. Phần này được chia theo từng đơn vị vận hành hạ tầng, sau đó xem xét riêng thời gian tồn tại của tên miền.

## Tên miền cấp cao nhất (TLD)

Theo Cơ quan Quản lý Số hiệu Internet (IANA), tính đến ngày 12 tháng 5 năm 2024 có hơn 1.440 TLD [104]. Chúng tôi tìm thấy 190 TLD bị tội phạm lợi dụng để triển khai các tên miền mới đăng ký được xác định là phục vụ phishing. Người dùng khó nhận diện các tên miền phishing sử dụng TLD bất thường [2]. Điều này góp phần giải thích tại sao tội phạm lợi dụng nhiều TLD khác nhau để đăng ký tên miền mới cho các hoạt động bất hợp pháp.

Chúng tôi khảo sát các TLD mà tội phạm ưa thích bằng cách tổng hợp những tên miền được đăng ký với mục đích độc hại trong Bảng 3. Không ngoài dự đoán, kết quả cho thấy .com là TLD bị lạm dụng nhiều nhất (55,2%), tiếp theo là .top (7,3%). Ngoài ra, trong tổng số tên miền mới đăng ký, .com có tỷ lệ tên miền đăng ký với mục đích độc hại cao thứ hai ($2{,}4 \times 10^{-4}$%), chỉ sau .top ($4{,}1 \times 10^{-4}$%). Kết quả này tương tự thống kê uy tín TLD của Spamhaus tính đến tháng 6 năm 2024 [105] và phù hợp với phần lớn nghiên cứu học thuật tương đối gần đây [6,23,106]. .com cũng là TLD bị lạm dụng nhiều nhất trong các chiến dịch smishing [107].

**Bảng 3. Mười TLD bị lạm dụng nhiều nhất để đăng ký tên miền mới lưu trữ website phishing và toàn bộ tên miền mới đăng ký (NRD) từ quý III năm 2023 đến quý II năm 2024 [112–115]. Tỷ lệ là phần trăm NRD xuất hiện trong tập dữ liệu của chúng tôi.**

| TLDs | Tên miền | | |
|---|---|---|---|
| | Dữ liệu nghiên cứu | Toàn bộ NRD | Tỷ lệ |
| | # | Số lượng (triệu) | % ($10^{-4}$) |
| com | 8347 | 36.9 | 2.3 |
| top | 1103 | 2.7 | 4.1 |
| info | 849 | | |
| online | 556 | 2.5 | 2.2 |
| xyz | 476 | 3.6 | 1.3 |
| net | 291 | 2.4 | 1.2 |
| bond | 237 | | |
| shop | 182 | 2.6 | 0.7 |
| site | 165 | 1.6 | 1.0 |
| delivery | 143 | | |
| ru | 143 | 2 | 0.7 |

Chúng tôi so sánh phân bố TLD của những tên miền được đăng ký với mục đích độc hại với phân bố website phishing năm 2022 do Kaspersky công bố [108] và nhận thấy hai phân bố phần nào tương đồng (Bảng 4). Tuy nhiên, tội phạm ưa chuộng .com hơn đáng kể khi đăng ký tên miền với mục đích độc hại; điều này không được phản ánh trong các báo cáo phishing của Kaspersky (kiểm định z cho hai tỷ lệ, so sánh tỷ lệ toàn bộ quần thể đăng ký dưới .com: giá trị $P < 0,0001$). Nguyên nhân có thể là sự khác biệt về dữ liệu Kaspersky phân tích, vì họ xem xét cả tên miền được đăng ký với mục đích độc hại lẫn tên miền bị xâm nhập. Kết quả của chúng tôi giúp các bên liên quan tập trung vào những TLD bị lạm dụng nhiều nhất để đăng ký tên miền độc hại, trong khi website bị xâm nhập có thể thuộc bất kỳ TLD nào. Sự phân biệt này rất quan trọng đối với việc xây dựng chiến lược phòng vệ và phân bổ nguồn lực của các bên liên quan.

**Bảng 4. Mười TLD đứng đầu trong tập dữ liệu của chúng tôi so với tập dữ liệu phishing năm 2022 của Kaspersky [108] và các TLD phổ biến nhất trên thế giới theo W3Techs năm 2023 [116]. Kiểm định z cho hai tỷ lệ ủng hộ nhận định rằng tỷ lệ phân bố .com trong các tên miền được đăng ký với mục đích độc hại tương đồng với tỷ lệ sử dụng TLD này trên toàn thế giới.**

| | Dữ liệu nghiên cứu | Phishing theo Kaspersky | | Dữ liệu nghiên cứu | W3Techs |
|---|---|---|---|---|---|
| **TLDs** | **(%)** | **(%)** | **TLDs** | **(%)** | **(%)** |
| com | 55.18 | 17.69 | com | 55.18 | 46.0 |
| xyz | 3.15 | 13.71 | org | 0.56 | 4.5 |
| fun | 0.06 | 7.85 | ru | 0.95 | 3.4 |
| org | 0.56 | 3.89 | de | 0.60 | 2.9 |
| top | 7.29 | 1.80 | net | 1.92 | 2.7 |
| ru | 0.95 | 1.52 | br | 0.00 | 2.4 |
| com.br | 0.01 | 1.13 | uk | 0.09 | 2.2 |
| co.uk | 0.35 | 0.98 | jp | 0.00 | 1.8 |
| de | 0.60 | 0.98 | fr | 0.05 | 1.6 |
| se | 0.02 | 0.92 | it | 0.00 | 1.6 |
| Khác | 31.83 | 54.44 | Khác | 40.65 | 69.1 |
| Kiểm định $\chi^2$ | $\chi^2 = 99$, df = 90, P = .2423 | | | $\chi^2 = 80.667$, df = 72, P = .2266 | |
| Kiểm định z hai tỷ lệ | P < .0001 | | | P = .2473 | |
| KTC 95%: | (0.2420, 0.5077) | | | (−0.0562, 0.2398) | |

Mặc dù .com thường được xem là đắt hơn các TLD dùng chung khác, phí đăng ký của nó thường tương đương những TLD thay thế. Chẳng hạn, chúng tôi nhận thấy giá đăng ký royalbankverification dưới TLD .com tương đương các TLD khác, như Hình A3 minh họa. Chúng tôi giả thuyết rằng tội phạm lợi dụng tên miền .com để đánh lừa người dùng vì chúng dễ tạo lòng tin hơn: URL hợp pháp của phần lớn thương hiệu toàn cầu bị mạo danh để phishing sử dụng .com. TLD .com được cung cấp rộng rãi nên dễ tìm nhiều nhà đăng ký tiềm năng. Những TLD lâu đời như .com cũng ít có khả năng bị các nhà cung cấp bảo mật tự động chặn; một số nhà cung cấp đôi khi chặn tên miền dựa trên TLD [109–111].

Tương tự kết quả của chúng tôi, nghiên cứu trước đây nhận thấy những TLD lâu đời như .com lưu trữ nhiều nội dung xấu hơn các TLD dùng chung mới [106,107]. Chúng tôi so sánh kết quả về lạm dụng TLD với mức sử dụng những TLD phổ biến trên thế giới theo W3Techs [116], nhằm xác định liệu mức lạm dụng có mất cân đối so với việc sử dụng hợp pháp các TLD phổ biến hay không. Phân bố lạm dụng .com cho phishing dường như tuân theo phân bố sử dụng .com trên toàn thế giới ($\chi^2$: P = 0,2266; kiểm định Z cho hai tỷ lệ: P = 0,2473).

Mặc dù tăng giá .com có thể ngăn cản hành vi lạm dụng này [117], chúng tôi không khuyến nghị đây là giải pháp khả thi. .com được sử dụng rộng rãi. Việc tăng chi phí đăng ký sẽ ảnh hưởng không cân xứng đến người dùng hợp pháp và có thể khiến nhiều người không còn khả năng sử dụng TLD phổ

biến này (xem Bảng 4). Giải quyết vấn đề đòi hỏi nhiều hơn cách xử lý chạy theo từng vụ việc [102]. Thay vào đó, chúng tôi đề xuất các nhà đăng ký tên miền chủ động hơn, đình chỉ những tên miền được đăng ký với mục đích độc hại và thực hiện thẩm tra kỹ trước khi đăng ký [118]. Chiến lược này giúp giảm lạm dụng các TLD có uy tín mà không gây ảnh hưởng tiêu cực đến người dùng hợp pháp.

Trong Bảng 5, chúng tôi phân loại những tên miền độc hại mới đăng ký theo hệ thống phân loại TLD của IANA [34]. Phần lớn tên miền (93,8%) lạm dụng gTLD, tiếp theo là ccTLD. Tội phạm mạng có thể lựa chọn gTLD dựa trên các thương hiệu và lĩnh vực mà chúng nhắm đến. Chẳng hạn, .delivery và .online lần lượt lưu trữ các website phishing nhắm vào thương hiệu giao nhận bưu kiện như UPS (ví dụ: tracking-ups.delivery), An Post (ví dụ: anpost.delivery) và các cổng đăng nhập trực tuyến (ví dụ: myrbcprofile.online).

**Bảng 5. Các tên miền theo nhóm TLD trong tập dữ liệu của chúng tôi so với DomainTools.**

| | Dữ liệu nghiên cứu | | DomainTools |
|---|---|---|---|
| **Nhóm TLD** | **TLDs** | **Tên miền** | **Tên miền** |
| Dùng chung (gTLD) | 134 | 14 191 | 217 triệu |
| Mã quốc gia (ccTLD) | 51 | 889 | 122 triệu |
| Dùng chung hạn chế (grTLD) | 3 | 42 | 2 triệu |
| Được bảo trợ (sTLD) | 2 | 4 | 583 nghìn |
| Hạ tầng (.arpa) | 0 | 0 | 0 |
| Thử nghiệm (tTLD) | 0 | 0 | 0 |

Chúng tôi xác định 51 ccTLD; nói đơn giản, đây thường là những lựa chọn TLD rẻ hơn. Có 42 tên miền lạm dụng các TLD dùng chung có hạn chế như .name, .biz và .pro, trong khi chỉ bốn tên miền lạm dụng các TLD được bảo trợ như .asia và .tel. Phân bố những tên miền này gần giống phân bố toàn bộ tên miền theo DomainTools, đơn vị thống kê toàn diện bằng tệp vùng DNS và số lượng tên miền của các cơ quan quản lý đăng ký [119].

Tội phạm lợi dụng các dịch vụ lưu trữ web miễn phí để triển khai website phishing [87,120]. Chúng tôi chỉ xác định được 35 tên miền (0,23%) lạm dụng các miền miễn phí của Google: .web.app và .firebaseapp.com. Nguyên nhân có thể là người dùng dễ nhận ra tên miền phishing sử dụng các đuôi này hơn. Google cũng có thể gỡ bỏ hoặc chặn các website phishing này nhanh hơn do chúng nằm trên hạ tầng của Google.

## Nhà đăng ký tên miền

Tập dữ liệu của chúng tôi xác định hơn 200 nhà đăng ký bị tội phạm lợi dụng để đăng ký các tên miền mới phục vụ lưu trữ website phishing. Chúng tôi lưu ý rằng việc tra cứu WHOIS [93] đối với 226 tên miền không trả về nhà đăng ký; trong đó có 138 ccTLD, còn lại là gTLD. Trong Bảng 6, chúng tôi so sánh mười nhà đăng ký bị tội phạm mạng lạm dụng nhiều nhất để triển khai tên miền phishing mới đăng ký với năm nhà đăng ký bị lạm dụng nhiều nhất cho các tên miền phục vụ xâm phạm email doanh nghiệp theo APWG [121,122].

**Bảng 6. Mười nhà đăng ký bị lạm dụng nhiều nhất để đăng ký các tên miền phishing mới tạo (n = 14.900); năm nhà đăng ký đứng đầu theo APWG bị lạm dụng để triển khai tên miền phục vụ xâm phạm email doanh nghiệp (BEC) [121,122]; và mười nhà đăng ký đứng đầu về thị phần tính theo số tên miền đã đăng ký [123].**

| Dữ liệu nghiên cứu | | Nhà đăng ký theo APWG | | Nhà đăng ký hàng đầu | |
|---|---|---|---|---|---|
| **Nhà đăng ký** | **Tên miền** | **Quý III/2023** | **Quý I/2024** | **Nhà đăng ký** | **Thị phần (%)** |
| NameSilo | 3331 | Namecheap | Namecheap | GoDaddy | 11.36 |
| NiceNIC | 2182 | Squarespace | Squarespace | Namecheap | 2.85 |
| Alibaba | 876 | 1&1 IONOS | Hostinger | Tucows | 1.67 |
| GoDaddy | 675 | Hostinger | Tucows | Squarespace | 1.22 |
| PublicDomainRegistry | 653 | NameSilo | 1&1 Ionos | GMO Internet Group | 0.85 |
| OwnRegistrar | 561 | | | Dynadot | 0.85 |
| Hosting Concepts B.V. | 509 | | | Ionos | 0.84 |
| Tucows | 480 | | | NameSilo | 0.81 |
| Jogjacamp | 398 | | | Gname | 0.77 |
| Reg.ru | 396 | | | Network Solutions | 0.73 |

Chúng tôi xác định NameSilo [chú thích 4] là nhà đăng ký bị lạm dụng nhiều nhất đối với tên miền phishing mới đăng ký, tiếp theo là NiceNIC [chú thích 5]. Nghiên cứu phishing năm 2021 sử dụng danh sách hỗn hợp [62] và một nghiên cứu smishing tập trung vào các báo cáo tại Hoa Kỳ [107] nhận thấy Namecheap bị lạm dụng nhiều nhất. Trong cùng giai đoạn thu thập dữ liệu, APWG báo cáo Namecheap [chú thích 6] bị lạm dụng nhiều nhất, sau đó là Squarespace [chú thích 7], để đăng ký các tên miền phục vụ xâm phạm email doanh nghiệp [121,122]. Ngược lại, chúng tôi chỉ nhận thấy Namecheap và Squarespace mỗi nhà đăng ký chiếm 2,1% tên miền độc hại. Mặt khác, thống kê uy tín của Spamhaus phù hợp với kết quả của chúng tôi, cho thấy NameSilo là nhà đăng ký bị lạm dụng nhiều nhất liên quan đến phishing [124].

Chúng tôi khảo sát NameSilo để hiểu vì sao tội phạm ưa chuộng nhà đăng ký này hơn những nơi khác. Chúng tôi tìm thấy các dịch vụ AI miễn phí trên NameSilo có thể giúp tội phạm nhanh chóng tạo tên miền. Hình A4 là ảnh chụp website của nhà đăng ký, nơi một cá nhân có thể dùng AI tạo những tên phát âm tương tự từ các lựa chọn trên website. Tiếp theo, chúng tôi xem xét nhà đăng ký được ưa chuộng thứ hai là NiceNIC. Khả năng mua tên miền qua ví tiền mã hóa như Bitcoin có thể thu hút tội phạm đến NiceNIC [chú thích 8], vì giao dịch có tính ẩn danh thông qua định danh giả. NameSilo cũng chấp nhận giao dịch Bitcoin bên cạnh các phương thức thanh toán khác [chú thích 9].

## Các hệ thống tự trị (AS)

Chúng tôi khảo sát những địa chỉ IP bị tội phạm lợi dụng để lưu trữ tên miền. Mỗi tên miền được truy vấn ngay trong ngày chúng tôi nhận được luồng dữ liệu. Chỉ 10.326 tên miền (68,3%) phân giải ra địa chỉ IP; những tên miền còn lại đã bị gỡ bỏ khi chúng tôi nhận dữ liệu, hoặc không phân giải như một biện pháp ứng phó việc gỡ bỏ hay một nỗ lực che giấu [125]. Một phần đáng kể trong số tên miền phân giải được, gồm 2.681 tên miền (26%), sử dụng dịch vụ proxy ngược Cloudflare. Để đối chiếu,

tính đến tháng 3 năm 2025, 19,3% tổng số website sử dụng dịch vụ này [126]. Dịch vụ cho phép người dùng che giấu địa chỉ IP của tên miền bằng cách chuyển tiếp qua các dải IP Cloudflare [chú thích 10]. Bản thân Cloudflare không lưu trữ nội dung; các nhà nghiên cứu an ninh mạng cần liên hệ Cloudflare để xác định hạ tầng lưu trữ nội dung cho những tên miền đã phát hiện. Nghiên cứu smishing trước đây cũng phát hiện tội phạm lợi dụng Cloudflare [30]. Chúng tôi khảo sát các địa chỉ IP còn lại để xác định những AS bị tội phạm lạm dụng hoặc hợp tác với tội phạm nhằm triển khai tên miền mới đăng ký cho phishing. Qua đó, chúng tôi tìm được mười AS bị lạm dụng nhiều nhất như Bảng 7 trình bày. Nghiên cứu trước đây xác định Amazon là nhà cung cấp lưu trữ đứng đầu [30]; Amazon lưu trữ 726 tên miền trong tập dữ liệu của chúng tôi.

**Bảng 7. Mười AS lưu trữ nhiều tên miền phishing mới đăng ký nhất.**

| Mã AS | Tên AS | Tên miền |
|---|---|---|
| AS200593 | Prospero OOO | 1001 |
| AS16509, AS14618 | Amazon.com Inc | 736 |
| AS132203, AS45090 | Tencent | 421 |
| AS45102 | Alibaba (US) Technology Co. | 351 |
| AS47846 | SEDO GmbH | 321 |
| AS54467, AS6134 | XNNET LLC | 238 |
| AS133618 | Trellian Pty. Limited | 229 |
| AS200019 | ALEXHOST SRL | 218 |
| AS47583, AS204915 | Hostinger International Limited | 186 |
| AS46606 | Unified Layer | 169 |

Phần lớn mười AS đứng đầu đã tồn tại khoảng mười năm trở lên, ngoại trừ hai AS được đăng ký chưa đến hai năm trước: AS200593 [chú thích 11] và AS54467 [chú thích 12]. AS200593 lưu trữ hơn 1.000 tên miền, trong khi AS54467 chỉ lưu trữ 236 tên miền. Chúng tôi nhận thấy phân bố tên miền trên các địa chỉ IP thuộc AS54467 tương đối đồng đều, trung bình 1,2 tên miền trên mỗi địa chỉ IP; còn AS200593 có một số địa chỉ IP bị lạm dụng nhiều hơn những địa chỉ khác.

Chúng tôi khảo sát tất cả mối liên hệ giữa địa chỉ IP và tên miền. Từ đó, chúng tôi xác định bốn địa chỉ IP thuộc AS200593 (Prospero OOO) cùng lưu trữ 859 tên miền trong tập dữ liệu. Chúng tôi sử dụng API DNS thụ động của Spamhaus để tra cứu ngược IP, tìm các tên miền khác và hostname tương ứng mà những địa chỉ IP này đã lưu trữ trong năm trước đó, được tổng hợp ở Bảng 8. Qua kiểm tra thủ công những tên miền mới tìm thấy trên Prospero OOO, chúng tôi nhận thấy chúng bị lợi dụng để triển khai tên miền phishing, mạo danh nhiều thương hiệu của tổ chức tài chính, công ty viễn thông và giao nhận, bên cạnh những mục đích đáng ngờ khác. AS này xuất hiện trong nhiều danh sách lạm dụng vì lưu trữ nội dung độc hại và tham gia các hành vi tội phạm mạng khác [127], chẳng hạn cố gắng xâm nhập website WordPress [128]. Báo chí bảo mật gần đây cũng đề cập AS này, mô tả mối liên hệ giữa nó với các tên miền phishing nhắm đến nạn nhân và dẫn dụ họ tải mã độc về máy [129,130].

**Bảng 8. Bốn địa chỉ IP thuộc Prospero OOO (AS200593) lưu trữ các tên miền mới đăng ký bị lợi dụng cho phishing.**

| Địa chỉ IP | Dữ liệu nghiên cứu | Spamhaus pDNS | |
|---|---|---|---|
| | Tên miền | Tên miền | Hostname |
| IP 1 | 327 | 2644 | 2980 |
| IP 2 | 296 | 1473 | 2077 |
| IP 3 | 121 | 696 | 886 |
| IP 4 | 115 | 1686 | 2072 |

## Chứng chỉ TLS

Tội phạm lợi dụng các cơ quan chứng thực (CA) để lấy chứng chỉ TLS cho tên miền được đăng ký với mục đích độc hại. Chúng tôi tìm thấy 109.570 chứng chỉ TLS được cấp cho 11.996 tên miền (79,3%), bởi 91 định danh đơn vị cấp TLS khác nhau tương ứng với 34 tổ chức cấp chứng thư. 3.130 tên miền còn lại chưa từng được cấp chứng chỉ TLS. Tương tự nghiên cứu trước đây [62], chúng tôi nhận thấy tội phạm lạm dụng nhiều chứng chỉ TLS cho tên miền phishing: từ một đến 4.039 chứng thư trên mỗi tên miền, với trung vị là ba chứng thư.

Chúng tôi nhận thấy tội phạm lợi dụng ba cơ quan cấp chứng chỉ TLS lớn: Let’s Encrypt, Sectigo Ltd và Google Trust Services để thực hiện phishing trên tên miền mới đăng ký. Trong khi Let’s Encrypt và Google Trust Services cung cấp chứng thư SSL miễn phí, Sectigo thu phí do cung cấp những tính năng như thời hạn hiệu lực dài hơn nhiều và SSL cho nhiều tên miền [131]. Mặc dù khó xác định sự thật nền đầy đủ, chúng tôi quan sát thấy những tổ chức cấp TLS khác như ssl.com không phổ biến trong giới tội phạm. Nguyên nhân có thể là họ thu phí khá cao ngay cả với dịch vụ cơ bản [chú thích 13]. Lưu ý rằng dù chúng tôi đối chiếu các kết quả khác với những tập dữ liệu phishing hỗn hợp, các báo cáo xu hướng gần đây không có phân bố CA [121,122].

Let’s Encrypt là đơn vị cấp chứng chỉ TLS bị lạm dụng nhiều nhất [132], với hơn 77,5 nghìn chứng thư cấp cho hơn 10,1 nghìn tên miền phishing mới đăng ký (Bảng 9). Việc tội phạm ưa chuộng Let’s Encrypt không gây ngạc nhiên, vì tổ chức này cấp chứng chỉ TLS miễn phí và nhiều nền tảng lưu trữ, bảng điều khiển quản trị hợp tác với họ để cung cấp chứng thư. Nghiên cứu trước đây phân tích chứng thư của các tên miền được đăng ký với mục đích tội phạm mạng cũng ủng hộ phát hiện này [28]. Tuy nhiên, chứng chỉ TLS của Let’s Encrypt chỉ có hiệu lực 90 ngày; điều này có thể khiến tần suất xuất hiện của chúng trong tập dữ liệu cao hơn do cơ chế cấp và gia hạn.

**Bảng 9. Mười tổ chức cấp chứng chỉ TLS bị lạm dụng nhiều nhất đối với các tên miền mới đăng ký lưu trữ website phishing (n = 11.996), và những tổ chức cấp chứng thư được sử dụng rộng rãi nhất tính đến tháng 10 năm 2024 theo W3Techs, xét theo mức sử dụng tuyệt đối [135].**

| Dữ liệu nghiên cứu | | | | W3Techs | |
|---|---|---|---|---|---|
| **Tổ chức cấp** | **Số chứng chỉ** | **Số tên miền** | **Tên miền (%)** | **Tổ chức cấp** | **Thị phần (%)** |
| Let’s Encrypt | 77 594 | 10 140 | 67.0 | Let’s Encrypt | 60.4 |
| Sectigo Ltd / Comodo CA | 9038 | 2427 | 16.0 | GlobalSign | 16.1 |
| CPanel | 9032 | 676 | 4.5 | Sectigo | 6.2 |
| Google Trust Services | 6784 | 3623 | 23.9 | DigiCert | 4.5 |
| ZeroSSL | 4090 | 245 | 1.6 | GoDaddy | 4.0 |
| DigiCert | 1070 | 464 | 3.1 | IdenTrust | 2.1 |
| Cloudflare | 970 | 257 | 1.7 | Certum | 0.6 |
| GoDaddy | 402 | 244 | 1.6 | Actails | 0.5 |
| Apple | 187 | 4 | 0 | Secom Trust | 0.3 |
| Globalsign | 135 | 25 | 0.2 | Entrust | 0.1 |
| Kiểm định $\chi^2$ | $\chi^2 = 66$, df = 60, P = .2773 | | | | |
| Kiểm định z hai tỷ lệ | P = .4102 | | | KTC 95% của chênh lệch tỷ lệ: (−0.209, 0.077) | |

Let’s Encrypt không kiểm tra tên miền trước khi cấp chứng thư, đồng thời không cho rằng CA là bên trung gian phù hợp để can thiệp; họ lập luận rằng lưu lượng mã hóa đang trở thành nhu cầu thiết yếu và mọi website đều nên có khả năng mã hóa [133]. Tính đến tháng 6 năm 2024, Let’s Encrypt cung cấp chứng chỉ TLS cho gần 47% trong một triệu website đứng đầu trên Internet [134,135] và hơn 67% tên miền phishing mới đăng ký như Bảng 9 thể hiện. Tỷ lệ tên miền phishing lợi dụng Let’s Encrypt tuân theo tỷ lệ chung các website trên thế giới sử dụng chứng thư của tổ chức này: kiểm định $\chi^2$ so sánh phân bố tất cả CA được sử dụng trên toàn thế giới với phân bố CA của tên miền phishing cho P = 0,2773; kiểm định z cho hai tỷ lệ chỉ xét tỷ lệ website trong mẫu sử dụng Let’s Encrypt cho P = 0,4102. Điều này cho thấy dù có sự tập trung, mức tập trung gần với kỳ vọng nếu tội phạm mạng đưa ra quyết định giống những người vận hành tên miền thông thường.

Khác với các phép đo khác, trong đó mỗi tên miền tương ứng nhiều nhất với một nhà đăng ký hoặc một AS, chúng tôi tìm thấy nhiều chứng chỉ TLS ở một số tên miền. Tội phạm lạm dụng nhiều chứng thư cho cả tên miền có và không chứa tên thương hiệu. Ví dụ, myonlineportal[.]net là tên miền dùng chung bị lợi dụng để mạo danh nhiều thương hiệu; kể từ lần đăng ký đầu tiên, nó được sáu tổ chức khác nhau cấp 4.039 chứng thư SSL, trong đó 3.860 do Let’s Encrypt cấp và 150 do CPanel cấp. Bằng dịch vụ DNS thụ động Spamhaus, chúng tôi truy vấn tên miền để tìm các hostname liên quan và xác định 295 tên miền con trong năm trước đó [chú thích 14]. Qua đó phát hiện những tên miền con như verifyamznprime và servmicrosftmrorllnk, được dùng để mạo danh Amazon Prime và Microsoft.

Một ví dụ khác về mạo danh Royal Bank of Canada (RBC) là rbc-i[.]com, được cấp 2.588 chứng thư SSL: 1.618 do Let’s Encrypt cấp, số còn lại do Sectigo Ltd cấp. Dịch vụ DNS thụ động Spamhaus cho thấy tên miền được nhìn thấy lần đầu vào tháng 1 năm 2017 và không có tên miền con nào trong năm

trước đó. Số lượng chứng chỉ TLS cho thấy tên miền đã được đăng ký lại hoặc bị lạm dụng để mạo danh cùng một thương hiệu nhiều lần kể từ thời điểm ấy.

## Những thương hiệu bị nhắm đến

Chúng tôi khảo sát 15.212 tên miền nhắm đến hơn 50 thương hiệu khác nhau; những thương hiệu phổ biến nhất được nêu trong Bảng 10. Tổ chức tài chính là lĩnh vực bị nhắm đến nhiều nhất, tiếp theo là giao nhận và vận chuyển. Điều này khác với các báo cáo trong ngành. APWG báo cáo mạng xã hội là lĩnh vực bị nhắm đến nhiều nhất, sau đó là nhà cung cấp webmail và tổ chức tài chính [121,122]. Báo cáo State of the Phish năm 2024 của công ty an ninh mạng quốc tế Proofpoint xếp một công ty giao nhận, vận chuyển ở vị trí thương hiệu bị mạo danh nhiều thứ ba qua email [136]. Sự khác biệt có thể do nguồn dữ liệu APWG và Proofpoint tiếp nhận là các website hỗn hợp, bao gồm website bị xâm nhập hoặc tên miền được đăng ký với mục đích độc hại; còn luồng dữ liệu của chúng tôi chỉ gồm những tên miền được đăng ký với mục đích độc hại.

**Bảng 10. Mười thương hiệu bị mạo danh nhiều nhất để dẫn dụ nạn nhân.**

| Thương hiệu | Ngành | Tên miền |
|---|---|---|
| Royal Bank of Canada | Tài chính/ngân hàng | 1268 |
| Royal Mail | Giao nhận/vận chuyển | 1015 |
| Santander | Tài chính/ngân hàng | 916 |
| DHL | Giao nhận/vận chuyển | 889 |
| Apple | Công nghệ | 775 |
| EVRI | Giao nhận/vận chuyển | 702 |
| An Post | Giao nhận/vận chuyển | 497 |
| Barclays | Tài chính/ngân hàng | 277 |
| Deutsche Bank | Tài chính/ngân hàng | 240 |
| AIB | Tài chính/ngân hàng | 229 |

Tội phạm mạo danh các tổ chức tài chính và công ty giao nhận, vận chuyển bưu kiện để dẫn dụ nạn nhân cung cấp thông tin tài chính. Anderson và cộng sự nhận thấy những hình thức gian lận đã tồn tại lâu, như gian lận ngân hàng trực tuyến, gia tăng từ năm 2012 [137] đến năm 2019 [138]. Lừa đảo giao nhận, vận chuyển bưu kiện cũng đã tồn tại vài năm [139,140], nhưng tăng mạnh kể từ đại dịch [141] và thậm chí đứng đầu các hình thức lừa đảo tại một số quốc gia [142]. Không ngoài dự đoán, chúng phổ biến trong mùa lễ hội [143].

Chúng tôi xác định hơn 1.200 tên miền mới đăng ký mạo danh RBC. Một nguyên nhân có thể là tội phạm dễ triển khai website phishing cho thương hiệu này hơn những thương hiệu khác nhờ sử dụng bộ công cụ phishing. Bộ công cụ phishing là tập hợp công cụ giúp tội phạm nhanh chóng triển khai website phishing [11]. Nghiên cứu trước đây phân tích các bộ công cụ này đã cho thấy chúng được tội phạm dùng để nhắm vào các tổ chức tài chính [62,144].

Chúng tôi cũng xác định những thương hiệu toàn cầu phổ biến như DHL và Apple bị tội phạm nhắm đến. Việc mạo danh các thương hiệu được sử dụng rộng rãi giúp tội phạm dẫn dụ một tập nạn nhân lớn hơn nhiều, không bị giới hạn về địa lý. Điều này cho thấy tồn tại nhiều nhóm tác nhân đe dọa theo đuổi những chiến lược phishing khác nhau. Cũng như các bài báo khác trong lĩnh vực này, những thương hiệu chúng tôi xác định vừa phản ánh tấn công thực tế, vừa phản ánh độ lệch của dữ liệu nền do cách thu thập của nhà cung cấp dữ liệu.

## Phát hiện bằng các sản phẩm chống mã độc

Chúng tôi khảo sát khả năng các công ty bảo mật khác phát hiện những tên miền này bằng API của Google Safe Browsing, một tổ chức bảo mật lớn, và VirusTotal, dịch vụ tổng hợp chống mã độc nổi bật. Ngay khi nhận được luồng dữ liệu, chúng tôi đồng thời truy vấn các điểm cuối dịch vụ đối với từng tên miền trong số 15.126 tên miền.

Chúng tôi dùng VirusTotal để xác định có bao nhiêu nhà cung cấp chống mã độc gắn cờ các tên miền mới đăng ký đã được xác định là phục vụ phishing. Có 503 tên miền (3,3%) không trả về kết quả trên VirusTotal (Bảng 11). Số nhà cung cấp báo cáo kết quả cho mỗi tên miền dao động từ 51 đến 95, với trung vị là 91. Mặc dù 80,7% tên miền được ít nhất một nhà cung cấp đánh dấu độc hại, chỉ 4,3% tên miền được hơn 15 nhà cung cấp (16,5%) phát hiện. Điều này cho thấy các nhà cung cấp xây dựng danh sách chặn bằng nhiều cách khác nhau [145]. Nghiên cứu của chúng tôi tập trung vào tên miền mới đăng ký; những nhà cung cấp đợi đến khi đủ nhiều khách hàng tương tác với tên miền có thể đưa chúng vào danh sách sau thời điểm chúng tôi kiểm tra trạng thái bị chặn.

**Bảng 11. Kết quả phát hiện các tên miền phishing mới đăng ký bằng những sản phẩm chống mã độc trên VirusTotal (n = 14.623).**

| Kết quả VirusTotal | Tên miền |
|---|---|
| Độc hại = 0 và Đáng ngờ = 0 | 909 |
| Độc hại ≥ 1 | 12 206 |
| Độc hại ≥ 3 | 8281 |
| Độc hại ≥ 5 | 6179 |
| Độc hại ≥ 10 | 2604 |
| Độc hại ≥ 15 | 646 |
| Đáng ngờ ≥ 1 | 6714 |
| Đáng ngờ ≥ 3 | 297 |
| Đáng ngờ ≥ 5 | 1 |
| Đáng ngờ ≥ 10 | 0 |

Chúng tôi xem xét riêng Google Safe Browsing dù dịch vụ này đã được tích hợp trong VirusTotal, vì phương pháp thu thập khác nhau dẫn đến kết quả khác nhau. API Google Safe Browsing trả về chuỗi rỗng nếu tên miền không bị đánh dấu độc hại; nếu bị đánh dấu, API trả về loại đe dọa phát hiện được,

chẳng hạn social engineering — kỹ nghệ xã hội. Chúng tôi nhận thấy API này phát hiện 3.012 tên miền (19,9%) như Bảng 12 trình bày.

**Bảng 12. Kết quả Google Safe Browsing phát hiện các tên miền mới đăng ký bị lợi dụng cho phishing (n = 15.126), thông qua API, website báo cáo minh bạch và VirusTotal.**

| Google Safe Browsing | Tên miền không an toàn | Tên miền không an toàn một phần | Tên miền chưa phát hiện | Chưa có dữ liệu |
|---|---|---|---|---|
| API | 3012 | - | 12 114 | - |
| Báo cáo minh bạch | 3981 | 1898 | 4033 | 5214 |
| Trên VirusTotal | 2508 | - | 12 618 | - |

Đáng chú ý, website báo cáo minh bạch của Google Safe Browsing trả về kết quả chi tiết hơn API. Website này cung cấp thông tin về danh sách chặn theo cách dễ hiểu, chủ yếu dành cho người dùng web. Chúng tôi truy vấn những tên miền trong tập dữ liệu qua website báo cáo minh bạch và thu được các kết quả khác nhau như Hình 2 trình bày. Tương tự API, website trả về thông báo không tìm thấy nội dung không an toàn khi Google không phát hiện nội dung độc hại trên website (Hình B1); ngược lại, website thông báo trang không an toàn như Hình B2. Giao diện web còn hiển thị thêm hai khả năng: không có dữ liệu khi Google chưa nhìn thấy tên miền được truy vấn (Hình B3); hoặc cảnh báo một số trang trên website không an toàn khi chỉ một tên miền con hay một đường dẫn cụ thể bị xác định là lưu trữ hoặc phân phối nội dung độc hại (Hình B4). Website báo cáo minh bạch không phát hiện 4.033 tên miền (26,7%), đồng thời phát hiện một phần ở 1.898 tên miền (12,5%). Tuy nhiên, nó trả về không có dữ liệu đối với 5.214 tên miền (34,5%) như Bảng 12 trình bày.

Kết quả trên website báo cáo minh bạch Google Safe Browsing khác biệt và chi tiết hơn nhiều so với API. Điều này phản ánh ưu tiên tránh đưa cả tên miền vào danh sách chặn khi chỉ một trang hoặc một tên miền con chứa nội dung độc hại. Tuy nhiên, đối với nhà nghiên cứu bảo mật sử dụng API tự động để truy vấn tên miền, kết quả có thể khó diễn giải theo trực giác.

Chúng tôi cũng tìm thấy kết quả trái ngược khi so sánh API Google Safe Browsing với cờ Google Safebrowsing trên VirusTotal, phù hợp với nghiên cứu trước đây [146]. Google chỉ gắn cờ 2.508 tên miền (16,6%) là không an toàn trên VirusTotal, so với 19,9% qua API và 38,9% trên website báo cáo minh bạch (Bảng 12). Nguyên nhân có thể là độ trễ cập nhật VirusTotal. Chúng tôi khuyến khích những người sử dụng dữ liệu Google Safe Browsing cho các mục đích rất nhạy cảm với thời gian truy cập trực tiếp API hoặc báo cáo minh bạch.

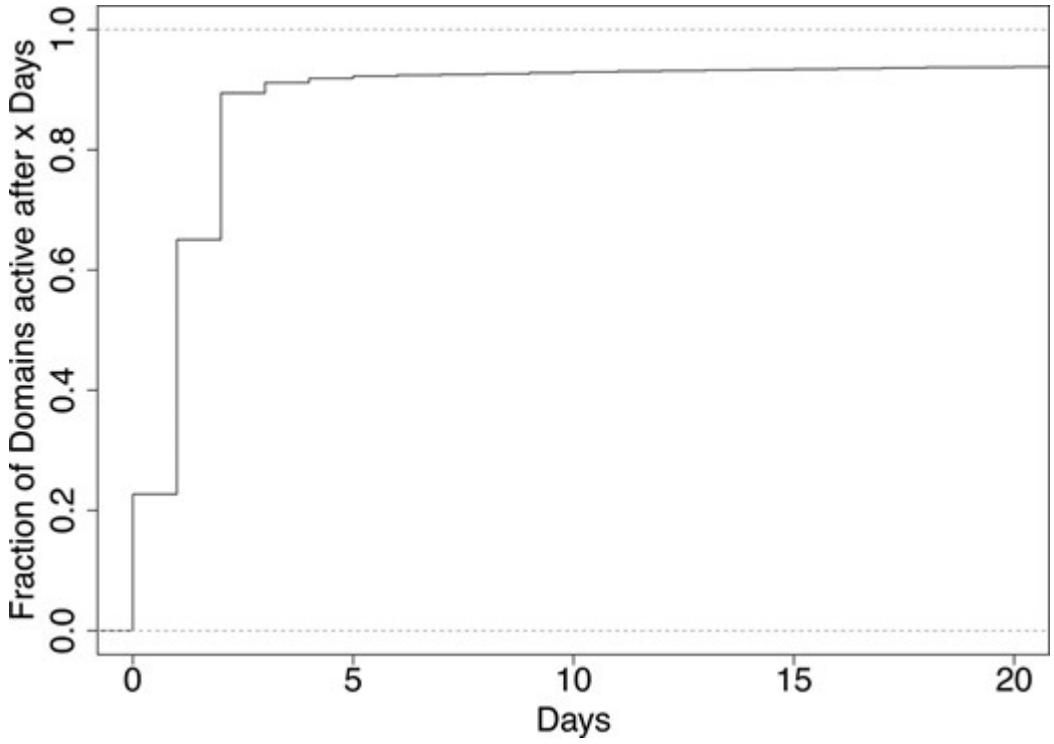
## Thời gian tồn tại của tên miền

Thời gian tồn tại của website phishing rất quan trọng vì tên miền hoạt động càng lâu càng có thể lừa nhiều nạn nhân. Các tác nhân đe dọa sử dụng nhiều chiến lược khác nhau để vận hành chiến dịch phishing. Chúng tôi coi ngày bắt đầu của tên miền là ngày nhà cung cấp dữ liệu xác định tên miền đó. Ngày kết thúc là lần cuối DNS thụ động Spamhaus ghi nhận tên miền được gắn với một địa chỉ IP, tức ngày cuối cùng nó còn phân giải tới một trang web. Nếu không có thông tin này, chúng tôi tính thời gian tồn tại bằng mốc gần nhất giữa ngày Spamhaus nhìn thấy tên miền và ngày chứng chỉ TLS mới nhất được cấp cho tên miền. Spamhaus có thể đã nhìn thấy tên miền trước khi đối tác của chúng tôi

xác định nó, và tội phạm có thể lấy chứng chỉ TLS trước hoặc ngay khi bắt đầu lưu trữ trang phishing. Hạn chế của cách tiếp cận này là có thể đánh giá thấp hoạt động ban đầu và đánh giá cao mức độ tồn tại dai dẳng.

Qua đó, chúng tôi xác định thời gian tồn tại của 14.112 tên miền được đăng ký với mục đích độc hại, dao động từ 0 đến 449 ngày, trung vị một ngày và trung bình 8,6 ngày. Nghiên cứu smishing trước đây quan sát thời gian tồn tại trung bình của tên miền là 12,241 ngày, với trung vị 0,53 giờ [30]. Để so sánh, nghiên cứu phishing trước đây nhận thấy tên miền không thuộc Rock Phish có thời gian tồn tại trung bình hơn hai ngày, còn tên miền fast-flux có thời gian trung bình 18 ngày [38]. Các công trình khác cũng ước tính website phishing hỗn hợp tồn tại trung bình ba ngày [12]. Chiến lược tội phạm sử dụng để triển khai tên miền được đăng ký với mục đích độc hại khác với chiến lược đối với website bị xâm nhập, từ đó ảnh hưởng đến thời gian tồn tại.

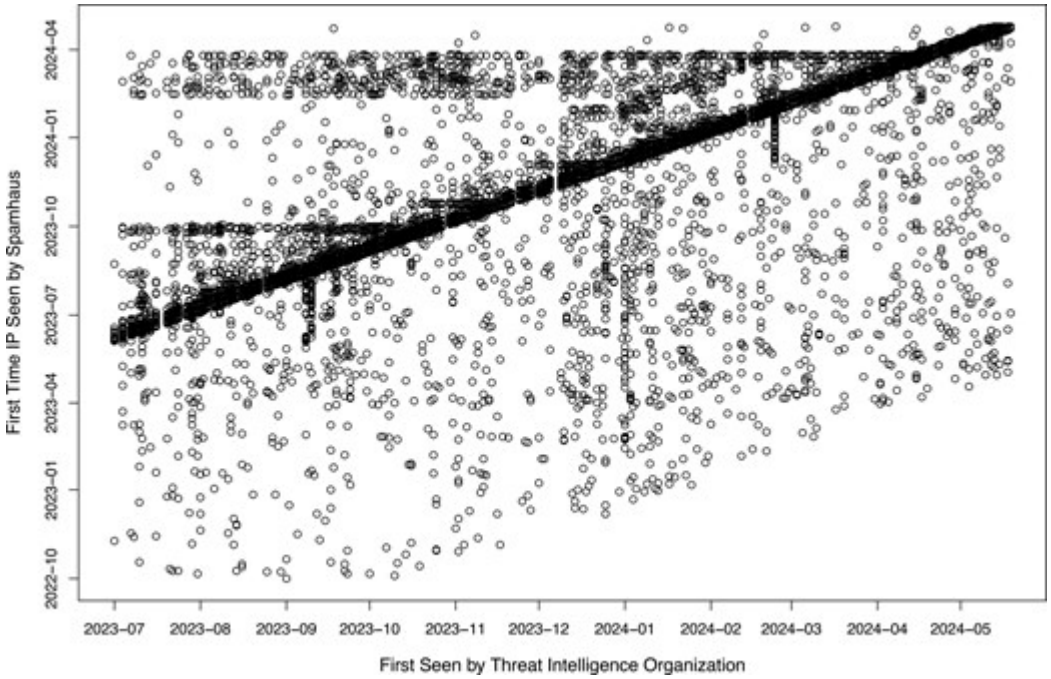
Chúng tôi phân tích phân bố thời gian tồn tại của những tên miền được đăng ký với mục đích độc hại (Hình 3). McGrath và Gupta [12] nhận thấy một phần ba website phishing hỗn hợp tồn tại 55 phút, trong khi một phần tư tồn tại 12 ngày. Trong khi đó, nghiên cứu của chúng tôi cho thấy 89,45% tên miền hoạt động dưới hai ngày và chỉ 6,59% hoạt động trên 15 ngày. Điều này chỉ ra rằng phần lớn tên miền được đăng ký với mục đích độc hại có thời gian tồn tại ngắn. Một nguyên nhân có thể là tên miền mới đăng ký bị gỡ bỏ nhanh hơn. Đối tác của chúng tôi chia sẻ các tên miền đã xác định với những bên liên quan, gồm nhà mạng di động, để lọc tin nhắn SMS chứa các tên miền này. Vì vậy, cũng có khả năng tội phạm chuyển sang tên miền khác khi kênh lạm dụng đã chặn tên miền cũ.




Hình 3. Phân bố tích lũy số ngày hoạt động của các tên miền phishing mới đăng ký (n = 14.112), với trung vị một ngày và trung bình 8,6 ngày.

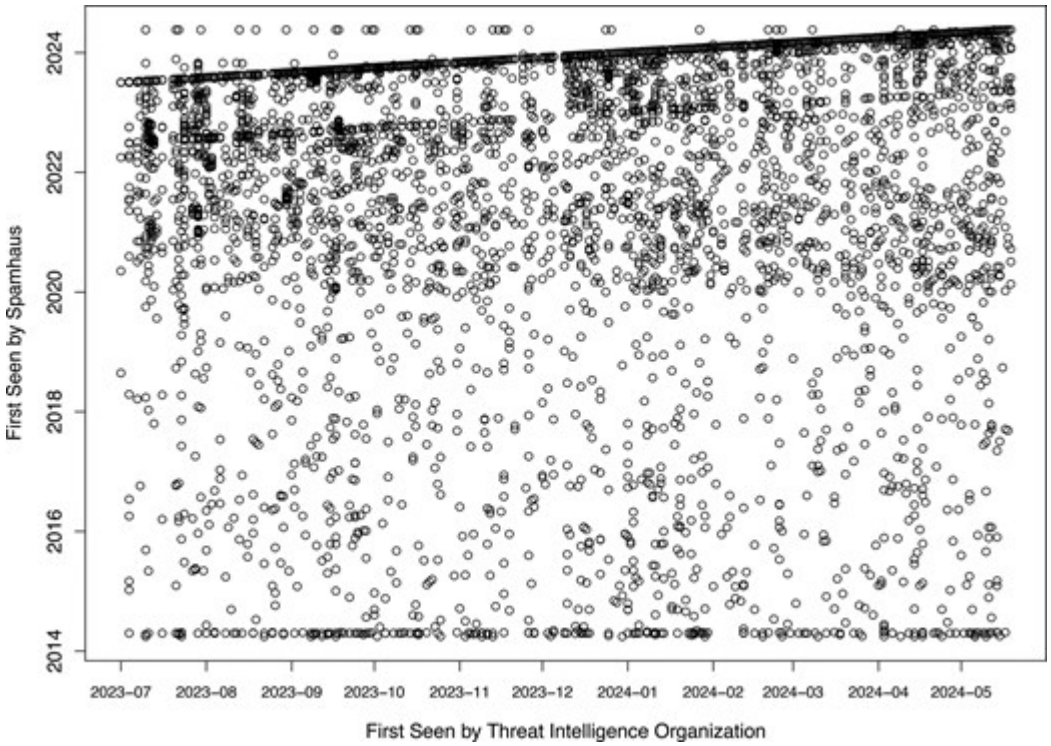
Trong mục Chứng chỉ TLS, chúng tôi xác định rằng nhiều chứng chỉ TLS đã được cấp cho các tên miền được đăng ký với mục đích độc hại qua nhiều năm; điều này bổ sung bằng chứng về việc tên miền được tái sử dụng cho phishing. Để khảo sát sâu hơn, Hình 4 biểu diễn ngày đầu tiên chúng tôi

nhận tên miền từ đối tác và ngày đầu tiên Spamhaus nhìn thấy những tên miền đó. Chúng tôi nhận thấy 27% tên miền được tội phạm đăng ký lại và tái sử dụng cho phishing. Kết quả phù hợp với công trình trước đây chỉ khảo sát .com [14].




Hình 4. Đối chiếu ngày bắt đầu với ngày Spamhaus nhìn thấy tên miền lần đầu (n = 15.126) cho thấy tội phạm đăng ký lại tên miền (n = 4.083).

Trong Hình 5, chúng tôi cũng biểu diễn ngày đầu tiên nhận tên miền từ đối tác so với dấu thời gian thu được từ DNS thụ động. Đồ thị cho thấy tội phạm lợi dụng tên miền để triển khai website phishing ngay sau khi đăng ký. Tuy nhiên, đôi khi chúng chờ qua các thuật toán phát hiện của nhà cung cấp chống mã độc trước khi triển khai website phishing. Điều này chỉ ra rằng các tác nhân đe dọa sử dụng những chiến lược phishing khác nhau.




Hình 5. Đối chiếu ngày bắt đầu với ngày đầu tiên tên miền được gắn với địa chỉ IP (n = 13.728) thể hiện khoảng thời gian tội phạm chờ sau khi đăng ký tên miền để thực hiện phishing.

# Thảo luận

Chống phishing từ tên miền đăng ký độc hại là nỗ lực hợp tác. Phần này thảo luận các hiểu biết chính và đề xuất biện pháp giảm thiểu cho các bên liên quan.

## Tội phạm mạng đăng ký tên miền để thực hiện smishing

Trong nhiều năm, các nhóm tấn công ưu tiên xâm nhập website hợp pháp để lưu trang phishing [9–12]. Nhận thấy người dùng và tổ chức chuyển sang SMS, chúng bắt đầu dụ người dùng qua tin nhắn. Khác email, SMS không thể che đường dẫn đầy đủ đến trang phishing trên website bị xâm nhập. Hiển thị URL đầy đủ của một website bị xâm nhập trong tin nhắn mạo danh một tổ chức hoàn toàn khác khó có thể dụ nạn nhân. Vì vậy, tội phạm ưu tiên đăng ký tên miền mới, lưu trang mạo danh thương hiệu rồi gửi qua SMS để đánh lừa người dùng hành động [40,41]. Hệ thống phát hiện lạm dụng SMS, RCS hoặc iMessage chưa tinh vi như bộ lọc email trong việc phát hiện và gắn cờ tin nhắn smishing chứa tên miền đăng ký độc hại.

Chúng tôi đề xuất các bên liên quan, gồm nhà mạng di động, hợp tác với tổ chức tình báo mối đe dọa để phát hiện và gỡ tên miền đăng ký độc hại. Bên phòng vệ cần ưu tiên giám sát tên miền mới, tìm dấu hiệu đăng ký hàng loạt hoặc mẫu hình liên quan chiến dịch lừa đảo SMS. Các đơn vị tổng hợp cũng cần phân biệt rộng rãi hơn tên miền phishing đăng ký độc hại với website bị xâm nhập để nhắm đúng bên có khả năng hành động phù hợp. Ví dụ, nhà cung cấp lưu trữ có thể giúp website bị xâm nhập dọn mã độc, nhưng dịch vụ đó không hiệu quả với tên miền được đăng ký để phạm tội.

## Hạ tầng mà tội phạm ưu tiên lợi dụng thay đổi theo thời gian

Đa số nghiên cứu hệ sinh thái phishing hiện có tập trung vào website bị xâm nhập hoặc nguồn hỗn hợp [9–12,45,83]. Dù đem lại hiểu biết phong phú về website nạn nhân bị tấn công để phục vụ phishing, kết luận chỉ áp dụng cho kiểu lạm dụng đó. Quy trình gỡ trang trên tên miền đăng ký độc hại khác với trên tên miền bị xâm nhập. Bộ phận tiếp nhận lạm dụng tại đơn vị hạ tầng cần xử lý hai kiểu khác nhau; không phân biệt sẽ khiến bước tiếp theo thiếu rõ ràng.

Hạ tầng bị tội phạm lợi dụng thay đổi theo năm, phụ thuộc biến động giá và chính sách mới của các bên nhằm giảm lạm dụng. Một số nghiên cứu gần đây xét TLD cụ thể [22,147], còn công trình này khảo sát dữ liệu tên miền đăng ký độc hại rộng hơn trên nhiều TLD. Năm 2020, Trung tâm An ninh mạng Quốc gia Anh xác định Namecheap phổ biến nhất trong SMS phishing mang chủ đề Chính phủ Anh [148]. Tuy nhiên, chúng tôi thấy nhà đăng ký được ưu tiên là NameSilo và .com là TLD bị lạm dụng nhiều nhất để đăng ký tên miền phishing mới [chú thích 15]. Điều này cho thấy lựa chọn của tội phạm thay đổi theo thời gian. Chúng tối đa lợi nhuận bằng cách luân chuyển tên miền mới, mua hạ tầng rẻ và chạy chiến dịch ngắn trước khi bị phát hiện. Bộ công cụ phishing [11] cho phép nhanh chóng tung số lượng lớn chiến dịch, nhắm nhiều nạn nhân trong thời gian ngắn.

Nhà đăng ký cần chủ động giám sát các TLD bị lạm dụng nhiều nhất để ngăn nhóm tấn công đăng ký tên miền mới; tiếp nhận nguồn tình báo từ bên phòng vệ để gỡ kịp thời tên miền đăng ký độc hại đã biết. Chúng tôi đề xuất cơ quan quản lý đăng ký phối hợp chặt với những nhà đăng ký liên kết bị lạm dụng nhiều hơn các đơn vị khác và chia sẻ hướng dẫn thực hành tốt để phát hiện, xử lý.

Một số AS thông đồng với tội phạm, cho phép hoạt động bất hợp pháp như phishing [149,150], thường được gọi là nhà cung cấp lưu trữ chống gỡ bỏ [42,151]. Ở mục Các hệ thống tự trị, chúng tôi nêu một AS tương đối mới bị lạm dụng nhiều hơn đáng kể. Bốn IP trong dải IP mới đăng ký của AS này đã lưu hơn 6 nghìn tên miền đáng ngờ trong năm qua. Điều đó cho thấy AS không chủ động phát hiện nội dung bất hợp pháp hoặc cố ý lưu website bất hợp pháp. Cũng có thể những đại lý bán lại bất hảo đang lợi dụng dải IP của một số AS để phishing. Dù tình huống chính xác là gì, nhà cung cấp lưu trữ có vai trò lớn trong thẩm tra đầy đủ và ngăn tác nhân xấu làm ô nhiễm Internet.

Dù đã có nguồn lực chuyên chống dịch vụ lưu trữ chống gỡ bỏ, chiến lược thường giống cuộc rượt đuổi: đánh sập đơn vị này thì đơn vị khác tiếp quản thị phần. Cần thêm nguồn lực để phá vòng lặp bằng việc nhiều đơn vị hơn, như nhà mạng di động, tham gia lọc mạnh và phát triển kỹ thuật mới khiến xây dựng hạ tầng dung dưỡng lạm dụng không còn sinh lợi [152].

## Các bên liên quan bỏ qua lịch sử lạm dụng tên miền

Khi xác định tên miền lạm dụng, bên phòng vệ báo các bên liên quan và yêu cầu chặn. Trái trực giác, tội phạm vẫn đăng ký lại tên miền từng bị lạm dụng. Dù đa số tên miền trong dữ liệu được đăng ký lần đầu, chúng tôi thấy tội phạm thường xuyên đăng ký lại để lưu website phishing (Hình 4). Những tên miền đã biết có hoạt động bất hợp pháp lại tiếp tục được đăng ký để phishing. Công trình khác thấy hơn 14% tên miền bị gỡ được đưa trở lại thị trường trong chưa đầy một năm [153]. Tên miền hết hạn có thể được bán lại, nhưng không có lý do hợp lệ để mua tên mạo danh tổ chức hợp pháp. Trước đây, tội phạm đăng ký lại tên miền hết hạn của tổ chức có uy tín để né phát hiện [13,14]; chúng tôi cho thấy chúng còn đăng ký lại tên miền vốn đã được đăng ký độc hại, như rbc-i[.]com được thấy lần đầu năm

2017. Chúng tôi đề xuất cấm vĩnh viễn tên miền mới dạng gõ sai đã được xác định dùng cho phishing [14]. Một số nhà đăng ký đã thẩm tra, nhưng cần nỗ lực tập thể lớn hơn từ ngành để hạn chế lạm dụng [154]. Áp dụng chiến lược phòng ngừa tội phạm theo tình huống có thể giảm cơ hội bằng cách tăng công sức cần thiết để phạm tội [155].

Tương tự, tên miền mới được cấp chứng chỉ TLS với trung vị ba chứng chỉ mỗi tên miền. Vì tội phạm thường lợi dụng CA [62], chúng tôi khuyến nghị CA kết hợp kết quả phát hiện của nhà cung cấp chống mã độc hoặc nguồn tình báo để đánh giá nguy cơ trước khi cấp. Let's Encrypt từng dùng kết quả Google Safe Browsing trước khi cấp chứng chỉ TLS [156,157]. Cách này có thể cần điều chỉnh bằng danh sách phù hợp hơn, chủ yếu chứa tên miền đăng ký độc hại. Khuyến nghị gắn với tranh luận lâu năm: CA có nên chịu trách nhiệm giảm thiểu lạm dụng khi vai trò của họ được giới hạn ở mã hóa có xác thực, không phải kiểm soát ý định người đăng ký? Một bộ phận cho rằng nên giữ nguyên phạm vi; bộ phận khác cho rằng bằng chứng lạm dụng CA cho phishing đòi hỏi can thiệp ngay khi cấp, tương tự kỳ vọng với nhà đăng ký và bên thứ ba khác. Chúng tôi đồng tình quan điểm sau trong trường hợp cụ thể của tên miền đăng ký độc hại, vì nguy cơ dương tính giả thấp hơn so với website hợp pháp bị xâm nhập. Tuy nhiên, chưa có nguồn công khai tốt để chia sẻ quy mô lớn tên miền đăng ký độc hại mà không lẫn tên miền bị xâm nhập, nên triển khai thực tế khá khó. Cần thêm công việc tách hai nhóm để các bên bị lợi dụng, như CA, có thể chống lạm dụng.

# Kết luận

Chúng tôi nghiên cứu 15.126 tên miền mới được tổ chức tình báo quốc tế cộng tác nhận diện. Công trình nhấn mạnh nhu cầu tiếp tục làm việc với nhà đăng ký và cơ quan quản lý đăng ký liên quan để ngăn lạm dụng nền tảng. Mức lạm dụng trên tên miền mới vẫn chưa được xử lý thỏa đáng. Trong khi các công trình khác nhấn mạnh .com và lạm dụng liên quan, chúng tôi lưu ý .com không nhất thiết bị lạm dụng quá mức trong nhóm tên miền phishing mới khi xét phân bố sử dụng, khác với những hướng lạm dụng khác. Chúng tôi đặc biệt quan ngại tên miền độc hại được đăng ký lại qua nhiều năm, điều đã được nghiên cứu trước nhấn mạnh [158]. Kết quả cung cấp bằng chứng về nhu cầu bảo vệ mọi cơ quan quản lý đăng ký khỏi lạm dụng. Mối lo tương tự áp dụng với chứng chỉ TLS được cấp rồi cấp lại nhiều lần, lên đến 4.039 lần, và không chỉ giới hạn ở nhà cung cấp chứng chỉ miễn phí.

Sự phổ biến của tên miền mới trong lừa đảo trực tuyến không phải phát hiện mới [72,74], nhưng công trình cho thấy đây vẫn là mối đe dọa ngày nay. Dù là kết quả thường gặp, nhiều nhà cung cấp bảo mật chưa chủ động xử lý. Trong khi tên miền ở nghiên cứu khác có mục đích hỗn hợp, tập trung vào tên miền mới có chủ đích độc hại cho phép hiểu hành vi tội phạm thay vì hành vi tương quan với website bị xâm nhập.

Dù phishing và lừa đảo trực tuyến khác là bất hợp pháp ở nhiều khu vực pháp lý, chúng thường không được cơ quan thực thi theo đuổi mà do cộng đồng có lợi ích tài chính hoặc nghề nghiệp trong chống phishing xử lý. Điều này khác nhiều loại tội phạm chủ yếu do cơ quan thực thi xử lý. Chúng tôi không đề xuất làm quá tải cảnh sát bằng từng email hay tên miền phishing, nhưng kêu gọi chính phủ xử lý vấn đề gia tăng bằng thực thi pháp luật phù hợp với nền tảng tạo điều kiện lạm dụng, như đã nêu khi bàn về AS, và/hoặc tạo động lực để nền tảng cấp đủ nguồn lực cho bộ phận tiếp nhận lạm dụng nhằm ngăn ngừa cả chủ động lẫn ứng phó.

## Xung đột lợi ích

Trong thời gian nghiên cứu, S.A. cũng làm việc tại Stop Scams UK. Mối liên hệ này không ảnh hưởng thiết kế, thực hiện hoặc kết quả nghiên cứu.


## Lời cảm ơn

Chúng tôi cảm ơn Cyber Defence Alliance đã hợp tác bằng cách chia sẻ nguồn dữ liệu. Chúng tôi cũng cảm ơn DNS Research Federation (DNSRF) và Spamhaus lần lượt cung cấp quyền truy cập dữ liệu APWG eCX và DNS thụ động.

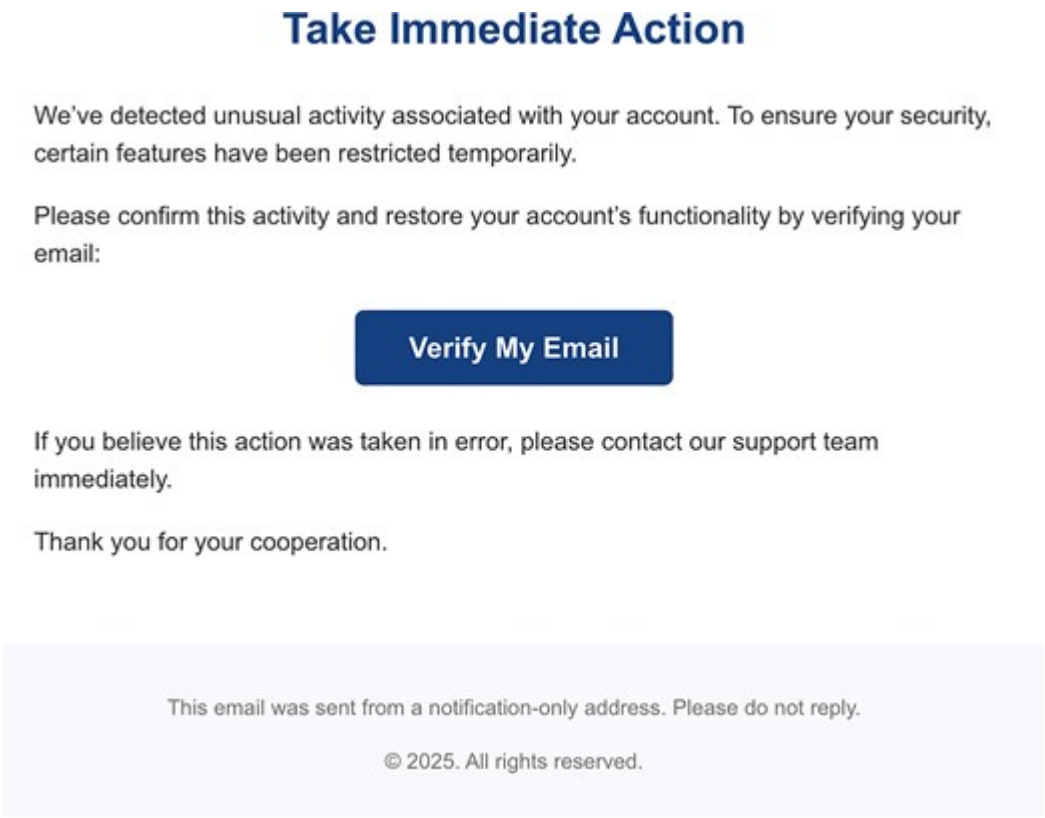

## Đóng góp tác giả

Sharad Agarwal: hình thành ý tưởng, biên soạn dữ liệu, phân tích chính thức, điều tra, phương pháp, tài nguyên, phần mềm, kiểm chứng, trực quan hóa, viết bản thảo ban đầu, rà soát và biên tập. Marie Vasek: huy động tài trợ, phương pháp, quản lý dự án, giám sát, kiểm chứng, trực quan hóa, viết bản thảo ban đầu, rà soát và biên tập.

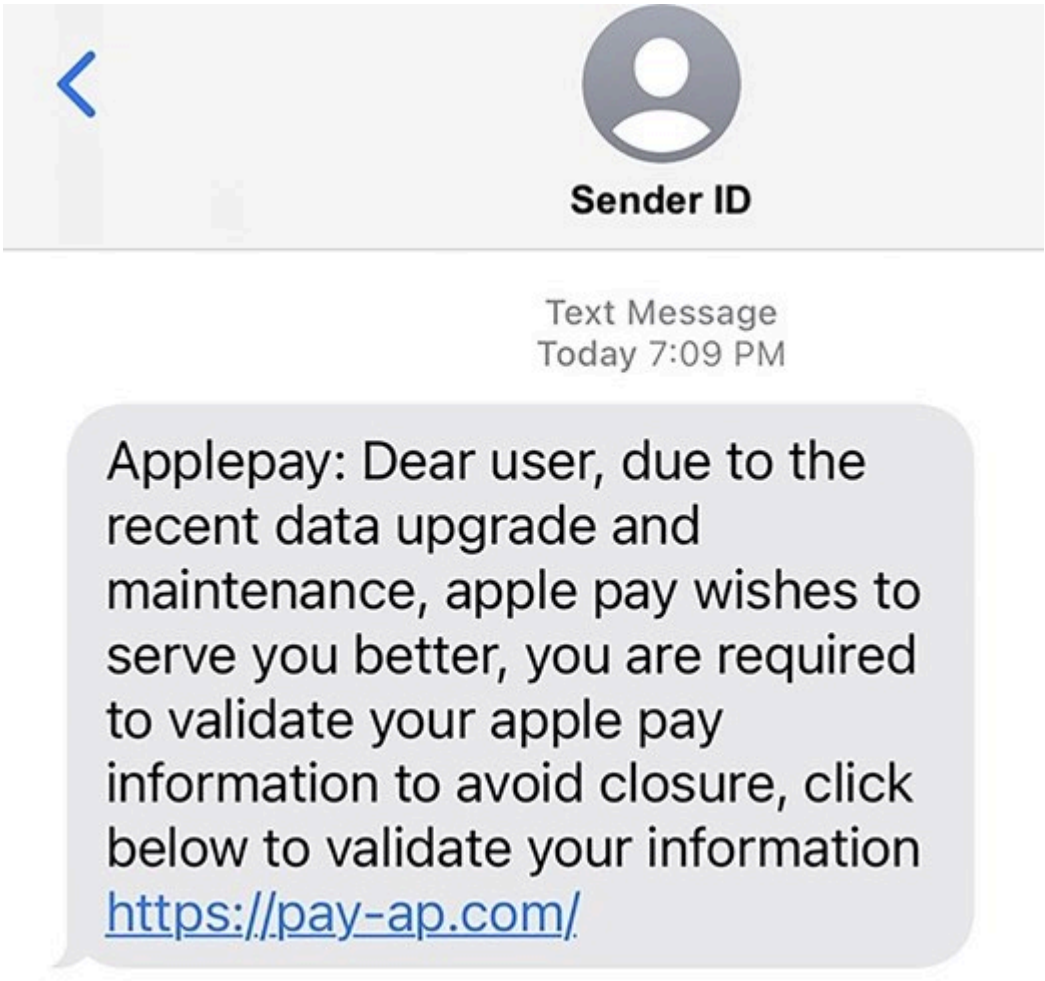

## Tài trợ

Không có khai báo.

## Phụ lục A: Ví dụ phishing và smishing



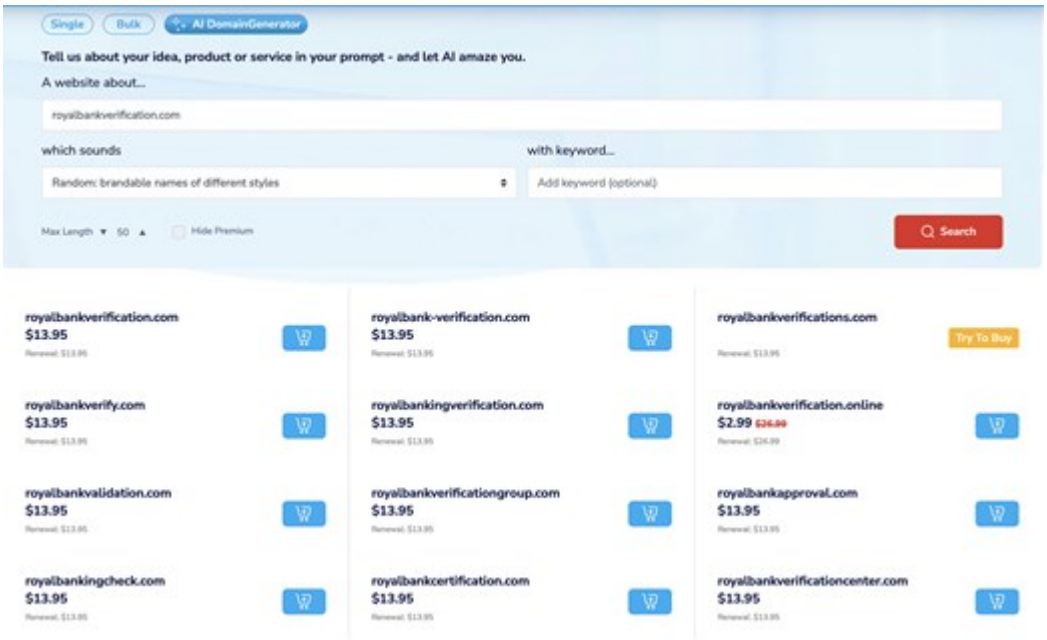

Hình A1. Ví dụ email phishing che giấu đường dẫn đầy đủ đến trang phishing bằng nút siêu liên kết.




Hình A2. Ví dụ SMS smishing sử dụng tên miền mới đăng ký.

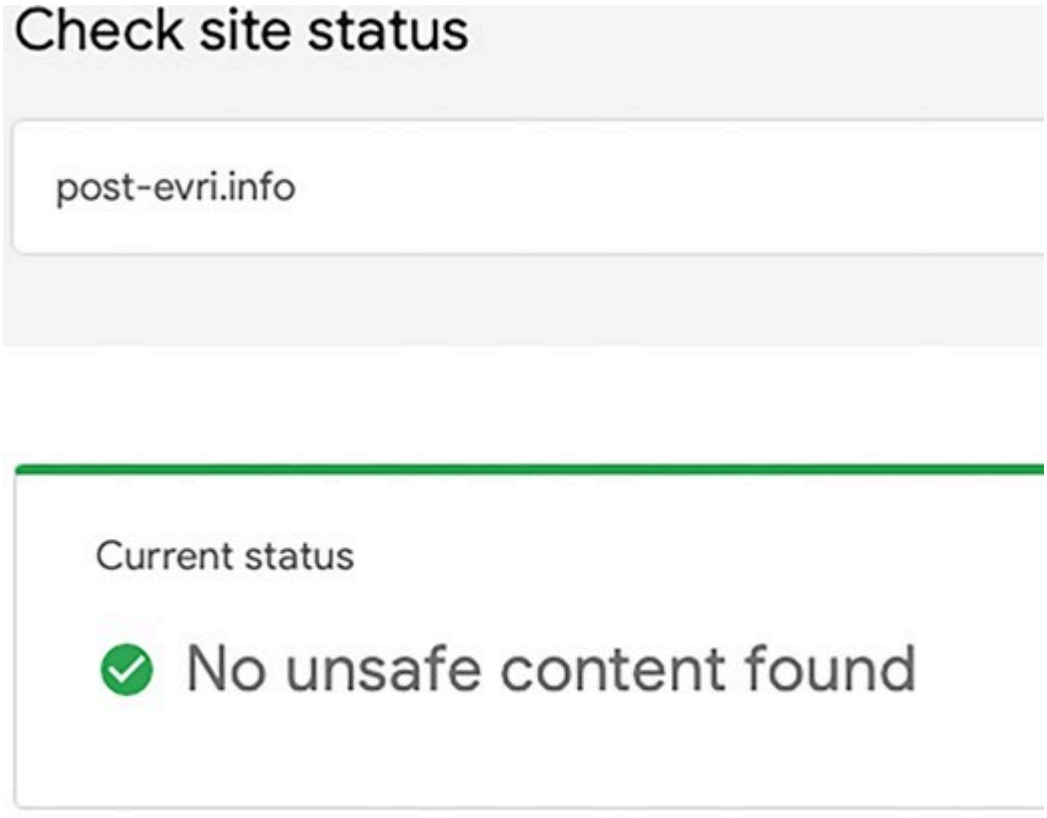



Hình A3. So sánh giá đăng ký một tên miền theo nhiều TLD trên NameSilo. TLD .com có giá tương tự các lựa chọn khác.

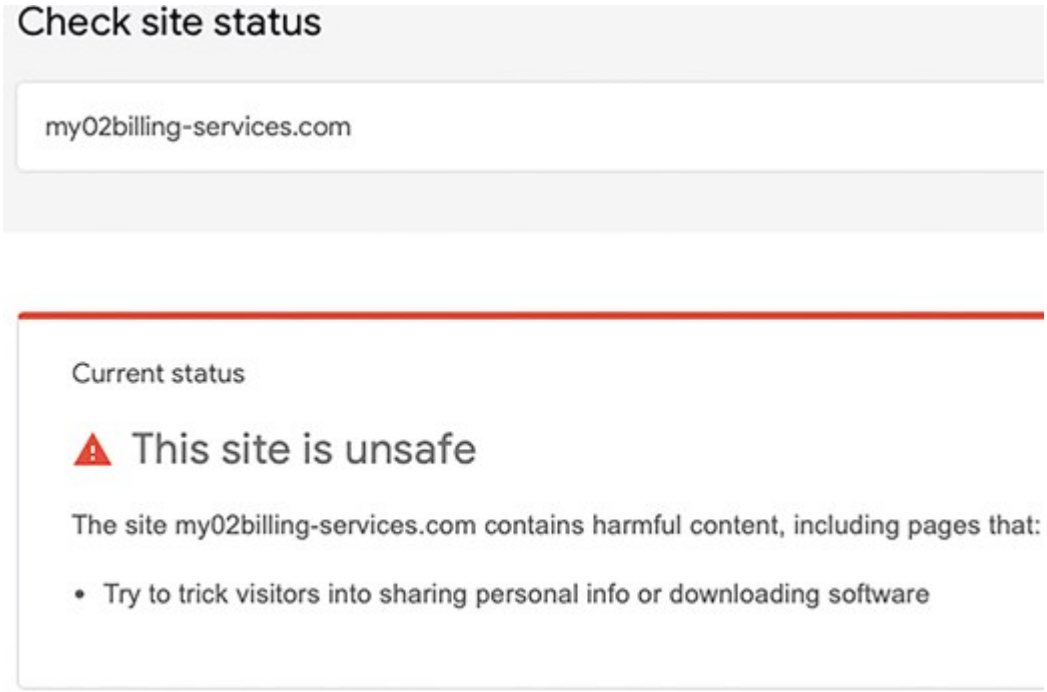



Hình A4. Tạo nhiều tên miền bằng dịch vụ AI của NameSilo. Phần lớn lựa chọn sinh ra dùng TLD .com với mức giá tối ưu.

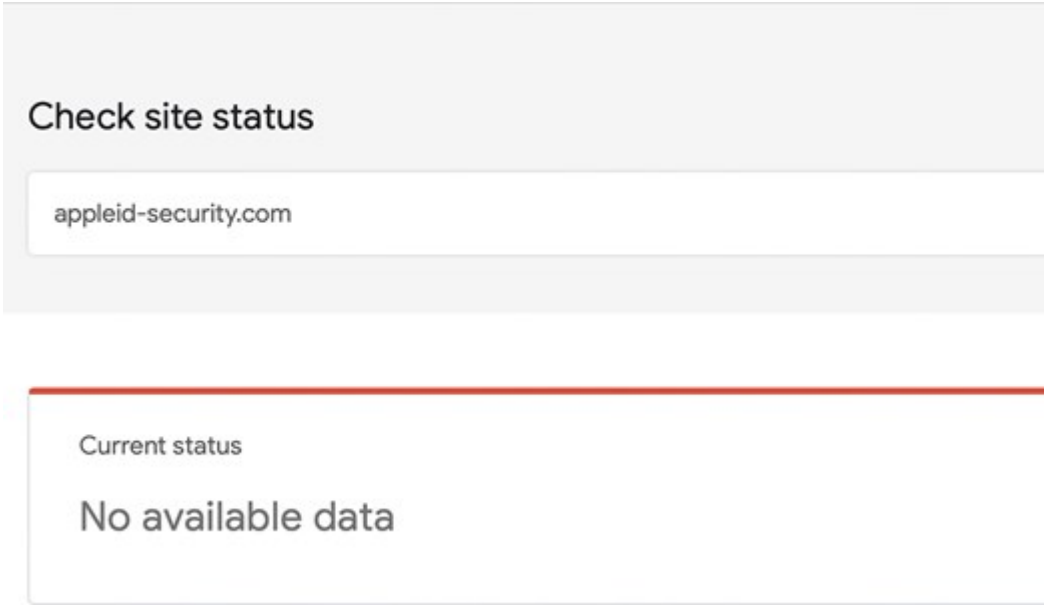
## Phụ lục B: Các kết quả có thể xuất hiện trên website báo cáo minh bạch của Google Safe Browsing



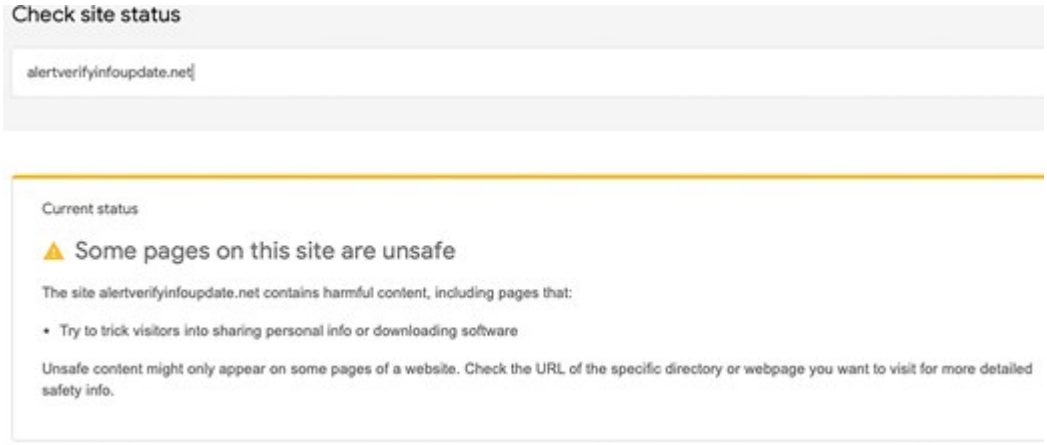

Hình B1. Không có nội dung không an toàn.




Hình B2. Tên miền không an toàn.




Hình B3. Không có dữ liệu.




Hình B4. Cảnh báo đối với một số trang trên tên miền.

# Chú thích cuối trang

1. Nhà đăng ký được ICANN công nhận — https://www.icann.org/en/accredited-registrars

2. Website phishing được báo cáo trên PhishTank — https://phishtank.com/phish_detail.php?phish_id=8959437

3. https://www.man.page/1/dig

4. https://www.namesilo.com/

5. https://nicenic.net/

6. https://www.namecheap.com/

7. https://domains.squarespace.com/

8. https://nicenic.net/news/messview.php?ID=21095

9. https://www.namesilo.com/payment-options#alter-payment

10. https://www.cloudflare.com/ips/

11. https://bgp.tools/as/200593

12. https://bgp.tools/as/54467

13. https://www.ssl.com/certificates/basicssl/

14. DNS thụ động của Spamhaus chỉ cho truy cập dữ liệu lịch sử một năm.

15. Vì dữ liệu chỉ từ một nhà cung cấp và thiên về thương hiệu tại các nước nói tiếng Anh, xu hướng có thể thay đổi khi quan sát hệ sinh thái rộng hơn. Tuy nhiên, mọi tập dữ liệu đều nhất thiết có thiên lệch theo hướng nào đó. Chúng tôi khuyến khích người có dữ liệu tên miền phishing mới riêng sử dụng phương pháp này để phân tích và công bố đối chiếu.

# Tài liệu tham khảo

1.Federal Bureau of Investigation (FBI). Federal Bureau of Investigation Internet Crime Report 2023. https://www.ic3.gov/Media/PDF/AnnualReport/2023_IC3Report.pdf (1 June 2024, date last accessed).

2.Quinkert F, Degeling M, Blythe J et al. Be the phisher–understanding users' perception of malicious domains. In: Proceedings of the 15th ACM Asia Conference on Computer and Communications Security. ASIA CCS '20. New York NY, USA: Association for Computing Machinery, 2020, 263–76.

3.Moore T, Edelman B. Measuring the perpetrators and funders of typosquatting. In: Proceedings of the International Conference on Financial Cryptography and Data Security. Berlin, Heidelberg: Springer, 2010, 175–91.

4.Kintis P, Miramirkhani N, Lever C et al. Hiding in plain sight: a longitudinal study of combosquatting abuse. In: Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security. CCS '17. New York NY, USA: Association for Computing Machinery, 2017, 569–86.

5.Wang YM, Beck D, Wang J et al. Strider Typo-Patrol: discovery and analysis of systematic typo-squatting. In: Proceedings of the 2nd Workshop on Steps to Reducing Unwanted Traffic on the Internet (SRUTI 06). San Jose CA, USA: USENIX Association, 2006.

6.Kumar N, Ghewari S, Tupsamudre H et al. When diversity meets hostility: a study of domain squatting abuse in online banking. In: Proceedings of the 2021 APWG Symposium on Electronic Crime Research (eCrime). Boston MA, USA: IEEE, 2021, 1–15.

7.Mutton P. LEGO vs cybersquatters: the burden of new gTLDs. London, UK: Netcraft, 2017. https://www.netcraft.com/blog/lego-vs-cybersquatters-the-burden-of-new-gtlds/ (1 June 2024, date last accessed).

8.Draganovic A, Dambra S, Iuit JA et al. Do users fall for real adversarial phishing?" Investigating the human response to evasive webpages. In: Proceedings of the 2023 APWG Symposium on Electronic Crime Research (eCrime). Barcelona, Spain: IEEE, 2023, 1–14.

9.Moore T, Clayton R. Evil searching: compromise and recompromise of internet hosts for phishing. In: Financial Cryptography and Data Security. Berlin, Heidelberg: Springer, 2009, 256–72.

10.Vasek M, Moore T. Identifying risk factors for webserver compromise. In: Financial Cryptography and Data Security. Berlin, Heidelberg: Springer, 2014, 326–45.

11.Oest A, Safei Y, Doupé A et al. Inside a phisher's mind: understanding the anti-phishing ecosystem through phishing kit analysis. In: Proceedings of the 2018 APWG Symposium on Electronic Crime Research (eCrime). San Diego, CA, USA: IEEE, 2018, 1–12.

12.McGrath DK, Gupta M. Behind phishing: an examination of phisher modi operandi. In: First USENIX Workshop on Large-Scale Exploits and Emergent Threats (LEET 08). San Francisco, CA: USENIX Association. 2008.

13.Moore T, Clayton R. The ghosts of banking past: empirical analysis of closed bank websites. In: Financial Cryptography and Data Security. Berlin, Heidelberg: Springer, 2014, 33–48.

14.Hao S, Thomas M, Paxson V et al. Understanding the domain registration behavior of spammers. In: Proceedings of the 2013 Conference on Internet Measurement Conference. IMC '13. New York, NY, USA: Association for Computing Machinery, 2013, 63–76.

15.Akiwate G, Savage S, Voelker GM et al. Risky BIZness: risks derived from registrar name management. In: Proceedings of the 21st ACM Internet Measurement Conference. IMC '21. New York, NY, USA: Association for Computing Machinery, 2021, 673–86.

16.Lauinger T, Onarlioglu K, Chaabane A et al. WHOIS lost in translation: (Mis)Understanding domain name expiration and re-registration. In: Proceedings of the 2016 Internet Measurement Conference. IMC '16. New York, NY, USA: Association for Computing Machinery, 2016, 247–53.

17.Bilge L, Kirda E, Kruegel C et al. Exposure: finding malicious domains using passive DNS analysis. In: Network and Distributed System Security. San Diego, CA, USA: Network and Distributed System Security (NDSS), 2011, 1–17.

18.Khalil I, Yu T, Guan B. Discovering malicious domains through passive DNS data graph analysis. In: Proceedings of the 11th ACM on Asia Conference on Computer and Communications Security. ASIA CCS '16. New York, NY, USA: Association for Computing Machinery, 2016, 663–74.

19.Manadhata P, Yadav S, Rao P et al. Detecting malicious domains via graph inference. In: Proceedings of the 2014 Workshop on Artificial Intelligent and Security Workshop. Cham: Springer, 2014, 59–60.

20.Shirazi H, Bezawada B, Ray I. “Kn0w Thy Doma1n Name” unbiased phishing detection using domain name based features. In: Proceedings of the 23nd ACM on symposium on access control models and technologies. New York, NY, USA: Association for Computing Machinery, 2018, 69–75.

21.Halvorson T, Der MF, Foster I et al. From.academy to.zone: an analysis of the New TLD Land Rush. In: Proceedings of the 2015 Internet Measurement Conference. IMC ’15. New York, NY, USA: Association for Computing Machinery, 2015, 381–94.

22.Vissers T, Spooren J, Agten P et al. Exploring the ecosystem of malicious domain registrations in the.eu TLD. In: Research in Attacks, Intrusions, and Defenses. Cham: Springer, 2017, 472–93.

23.Lever C, Walls R, Nadji Y et al. Domain-Z: 28 registrations later measuring the exploitation of residual trust in domains. In: Proceedings of the 2016 IEEE Symposium on Security and Privacy. San Jose, CA, USA: IEEE, 2016, 691–706.

24.Miramirkhani N, Barron T, Ferdman M et al. Panning for gold.com: understanding the dynamics of domain dropcatching. In: Proceedings of the 2018 World Wide Web Conference. WWW ’18. Republic and Canton of Geneva, CHE: International World Wide Web Conferences Steering Committee, 2018, 257–66.

25.Lauinger T, Buyukkayhan AS, Chaabane A et al. From deletion to re-registration in zero seconds: domain registrar behaviour during the drop. In: Proceedings of the Internet Measurement Conference 2018. IMC ’18. New York, NY, USA: Association for Computing Machinery, 2018, 322–8.

26.Maroofi S, Korczyński M, Hesselman C et al. COMAR: Classification of compromised versus maliciously registered domains. In: Proceedings of the 2020 IEEE European Symposium on Security and Privacy (EuroS&P). Genoa, Italy: IEEE, 2020, 607–23.

27.Silva RD, Nabeel M, Elvitigala C et al. Compromised or attacker-owned: a large scale classification and study of hosting domains of malicious URLs. In: Proceedings of the 30th USENIX Security Symposium (USENIX Security 21). USA: USENIX Association, 2021, 3721–38.

28.Kim D, Cho H, Kwon Y et al. Security analysis on practices of certificate authorities in the https phishing ecosystem. In: Proceedings of the 2021 ACM Asia Conference on Computer and Communications Security. ASIA CCS ’21. New York, NY, USA: Association for Computing Machinery, 2021, 407–20.

29.Interisle Cconsulting Group. Phishing Landscape 2024. 2024. https://static1.squarespace.com/static/63dbf2b9075aa2535887e365/t/66cde404c8345e766972319c/1724769286084/PhishingLandscape2024.pdf (1 August 2024, date last accessed).

30.Nahapetyan A, Prasad S, Childs K et al. On SMS phishing tactics and infrastructure. In: Proceedings of the 2024 IEEE Symposium on Security and Privacy. San Francisco, CA, USA: IEEE, 2024, 1–16.

31.Cloudflare. Browser Market Share Report for 2024 Q2. 2024. https://radar.cloudflare.com/reports/browser-market-share-2024-q2 (1 August 2024, date last accessed).

32.Oest A, Zhang P, Wardman B et al. Sunrise to sunset: analyzing the end-to-end life cycle and effectiveness of phishing attacks at scale. In: Proceedings of the 29th USENIX Security Symposium (USENIX Security 20). USA: USENIX Association, 2020, 361–77.

33.ICANN. ICANN for beginners. 2024. https://www.icann.org/en/beginners (1 August 2024, date last accessed).

34.Internet Assigned Numbers Authority (IANA). Root zone database. 2024. https://www.iana.org/domains/root/db (1 August 2024, date last accessed).

35.Bradley E. Domain watch-ing for phishers. 2019. https://www.nominet.uk/domain-watch-ing-for-phishers/ (1 August 2024, date last accessed).

36.ICANN. Advisory: Compliance with DNS abuse obligations in the registrar accreditation agreement and the registry agreement. 2024. https://www.icann.org/resources/pages/advisory-compliance-dns-abuse-obligations-raa-ra-2024-02-05-en (1 August 2024, date last accessed).

37.Vasek M, Moore T. Do malware reports expedite cleanup? An experimental study. In: Proceedings of the 5th Workshop on Cyber Security Experimentation and Test (CSET 12). Bellevue, WA: USENIX Association. 2012.

38.Moore T, Clayton R. An empirical analysis of the current state of phishing attack and defence. In: Workshop on the Economics of Information Security. Pittsburgh (PA), USA: WEIS. 2007.

39.Agten P, Joosen W, Piessens F et al. Seven months' worth of mistakes: a longitudinal study of typosquatting abuse. In: Network and Distributed System Security. San Diego, CA, USA: Network and Distributed System Security (NDSS. 2015.

40.SIDN. Typo domain names used for smishing. 2020. https://www.sidn.nl/en/news-and-blogs/typo-domain-names-used-for-smishing (1 August 2024, date last accessed).

41.Silent Push. IMP-1G: Silent Push tracks new US Gov smishing threat actor. 2024. https://www.silentpush.com/blog/imp-1g-smishing/ (1 November 2024, date last accessed ).

42.Mahjoub D. Behaviors and patterns of bulletproof and anonymous hosting providers. Usenix Enigma Conference. Oakland, CA, USA: USENIX Association. 2017.

43.Alrwais S, Liao X, Mi X et al. Under the shadow of sunshine: understanding and detecting bulletproof hosting on legitimate service provider networks. In: Proceedings of the 2017 IEEE Symposium on Security and Privacy (SP). San Jose, CA, USA: IEEE, 2017, 805–23.

44.Hale C. Domain registrars can now block users from registering typo-laden domains for nefarious purposes. 2024. https://www.techradar.com/pro/security/domain-registrars-can-now-block-users-from-registering-typo-laden-domains-for-nefarious-purposes (1 August 2024, date last accessed).

45.Moore T, Clayton R. Examining the impact of website take-down on phishing. In: Proceedings of the 2007 APWG eCrime Researchers Summit. New York, NY, USA: Association for Computing Machinery, 2007, 1–13.

46.Sterling B. Tainted address blocks. 2009. https://www.wired.com/2009/11/tainted-address-blocks/ (1 August 2024, date last accessed).

47.Nosyk Y, Korczynski M, Maroofi S et al. INFERMAL: inferential analysis of maliciously registered domains. 2024. https://www.icann.org/en/system/files/files/inferential-analysis-maliciously-registered-domains-08nov24-en.pdf (10 November 2024, date last accessed).

48.Corona I, Biggio B, Contini M et al. Deltaphish: detecting phishing webpages in compromised websites. In: Proceedings of the ESORICS 2017: 22nd European Symposium on Research in Computer Security. Cham: Springer, 2017, 370–88.

49.Soska K, Christin N. Automatically detecting vulnerable websites before they turn malicious. In: Proceedings of the 23rd USENIX Security Symposium (USENIX Security 14). San Diego, CA, USA: USENIX Association, 2014, 625–40.

50.Wardman B, Shukla G, Warner G. Identifying vulnerable websites by analysis of common strings in phishing URLs. In: Proceedings of the 2009 APWG eCrime Researchers Summit. Tacoma, WA, USA: IEEE, 2009, 1–13.

51.Canali D, Balzarotti D, Francillon A. The role of web hosting providers in detecting compromised websites. In: Proceedings of the 22nd International Conference on World Wide Web. New York, NY, USA: Association for Computing Machinery, 2013, 177–88.

52.Clayton R, Mansfield T. A study of Whois privacy and proxy service abuse. In: Proceedings of the 13th Workshop on the Economics of Information Security. Pennsylvania, USA: WEIS, 2014.

53.Moore T, Clayton R. The impact of public information on phishing attack and defense. Commun Strat. 2011;81:45.

54.Opsec Security. How can brands fight high-volume fraud?. 2024. https://www.opsecsecurity.com/insights/blog/how-can-brands-fight-high-volume-fraud/ (1 November 2024, date last accessed).

55.Resecurity. Smishing triad impersonates emirates post to target UAE citizens. 2023. https://www.resecurity.com/blog/article/Smishing-Triad-Impersonates-Emirates-Post-Target-UAE-Citizens (1 November 2024, date last accessed).

56.Oest A, Safaei Y, Doupé A et al. Phishfarm: a scalable framework for measuring the effectiveness of evasion techniques against browser phishing blacklists. In: Proceedings of the 2019 IEEE Symposium on Security and Privacy (SP). San Francisco, CA, USA: IEEE, 2019, 1344–61.

57.Fowler B. Check your messages: Scam texts on the rise. 2022. https://www.cnet.com/tech/services-and-software/check-your-messages-scam-texts-on-the-rise/ (1 November 2024, date last accessed).

58.Global Anti-Scam Alliance (GASA). Scammers steal £11.4 billion from Britons in 1 year as 71% fail to report scams - state of scams in the United Kingdom 2024. 2024. https://www.gasa.org/post/state-of-scams-in-the-united-kingdom-2024-11-billion-stolen (25 November 2024, date last accessed).

59.Ofcom. 45 million people targeted by scam calls and texts this summer. London, UK. 2021. https://www.ofcom.org.uk/phones-and-broadband/scam-calls-and-messages/45-million-people-targeted-by-scams/ (1 November 2024, date last accessed).

60.eFlow. Fraudulent text messages. 2024. https://www.eflow.ie/news/eflow-fraudulent-text-messages/ (1 August 2024, date last accessed).

61.Linkt. Latest scams and security alerts. Australia.2024. https://www.linkt.com.au/help/security/latest-scams (1 August 2024, date last accessed).

62.Bijmans H, Booij T, Schwedersky A et al. Catching phishers by their bait: Investigating the dutch phishing landscape through phishing kit detection. In: Proceedings of the 30th USENIX Security Symposium (USENIX Security 21). USA: USENIX Association Remote, 2021, 3757–74.

63.Chhabra S, Aggarwal A, Benevenuto F et al. Phi.sh/$oCiaL: the phishing landscape through short URLs. In: Proceedings of the 8th Annual Collaboration, Electronic Messaging, Anti-Abuse and Spam Conference. CEAS '11. New York, NY, USA: Association for Computing Machinery, 2011, 92–101.

64.Timko D, Rahman ML. Commercial anti-smishing tools and their comparative effectiveness against modern threats. In: Proceedings of the 16th ACM Conference on Security and Privacy in Wireless and Mobile Networks. WiSec '23. New York, NY, USA: Association for Computing Machinery, 2023, 1–12.

65.ICANN. AGP (Add Grace Period) limits policy. 2008. https://www.icann.org/resources/pages/agp-policy-2008-12-17-en (1 August 2024, date last accessed).

66.Coull SE, White AM, Yen TF et al. Understanding domain registration abuses. Comput Secur. 2012;31:806–15.

67.Milletary J. Technical trends in phishing attacks. 2005. https://insights.sei.cmu.edu/library/technical-trends-in-phishing-attacks/ (1 August 2024, date last accessed).

68.Barron T, Miramirkhani N, Nikiforakis N. Now you see it, now you Don't: A large-scale analysis of early domain deletions. In: Proceedings of the 22nd International Symposium on Research in Attacks, Intrusions and Defenses (RAID 2019). Beijing, China: USENIX Association, 2019, 383–97.

69.Hao S, Feamster N, Pandrangi R. Monitoring the initial DNS behavior of malicious domains. In: Proceedings of the 2011 ACM SIGCOMM Conference on Internet Measurement Conference. IMC '11. New York, NY, USA: Association for Computing Machinery, 2011, 269–78.

70.Felegyhazi M, Kreibich C, Paxson V. On the potential of proactive domain blacklisting. In: Proceedings of the 3rd USENIX Conference on Large-Scale Exploits and Emergent Threats: Botnets, Spyware, Worms, and More. LEET'10. San Jose, CA, USA: USENIX Association, 2010, 6.

71.Yadav S, Reddy AKK, Reddy ALN et al. Detecting algorithmically generated malicious domain names. In: Proceedings of the 10th ACM SIGCOMM Conference on Internet Measurement. IMC '10. New York, NY, USA: Association for Computing Machinery, 2010, 48–61.

72.Tian K, Jan STK, Hu H et al. Needle in a haystack: tracking down elite phishing domains in the wild. In: Proceedings of the Internet Measurement Conference 2018. IMC '18. New York, NY, USA: Association for Computing Machinery, 2018, 429–42.

73.Zhauniarovich Y, Khalil I, Yu T et al. A survey on malicious domains detection through DNS data analysis. ACM Comput Surv. 2018;51:1–36.

74.Prakash P, Kumar M, Kompella RR et al. PhishNet: predictive blacklisting to detect phishing attacks. In: 2010 Proceedings IEEE INFOCOM. San Diego, CA, USA: IEEE, 2010, 1–5.

75.Antonakakis M, Perdisci R, Dagon D et al. Building a dynamic reputation system for DNS. In: Proceedings of the 19th USENIX Security Symposium (USENIX Security 10). Washington, DC, USA: USENIX Association, 2010.

76.Hao S, Kantchelian A, Miller B et al. PREDATOR: proactive recognition and elimination of domain abuse at time-of-registration. In: Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security. New York, NY, USA: Association for Computing Machinery, 2016, 1568–79.

77.Lauinger T, Chaabane A, Buyukkayhan AS et al. Game of registrars: an empirical analysis of Post-Expiration domain name takeovers. In: Proceedings of the 26th USENIX Security Symposium (USENIX Security 17). Vancouver, BC, Canada: USENIX Association, 2017, 865–80.

78.Nikiforakis N, Invernizzi L, Kapravelos A et al. You are what you include: large-scale evaluation of remote javascript inclusions. In: Proceedings of the 2012 ACM Conference on Computer and Communications Security. CCS '12. New York, NY, USA: Association for Computing Machinery, 2012, 736–47.

79.Vissers T, Barron T, Van Goethem T et al. The Wolf of Name Street: hijacking domains through their nameservers. In: Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security. CCS '17. New York, NY, USA: Association for Computing Machinery, 2017, 957–70.

80.Schlamp J, Carle G, Biersack EW. A forensic case study on as hijacking: the attacker's perspective. SIGCOMM Comput Commun Rev. 2013;43:5–12.

81.Schlamp J, Gustafsson J, Wählisch M et al. The abandoned side of the internet: hijacking internet resources when domain names expire. In: Traffic Monitoring and Analysis. Cham: Springer, 2015, 188–201.

82.Drake CE, Oliver JJ, Koontz EJ. Anatomy of a phishing email. In: Proceedings of the First Conference on Email and Anti-Spam. Crystal Drive: CEAS, 2004.

83.Sheng S, Wardman B, Warner G et al. An empirical analysis of phishing blacklists. In: Proceedings of the Conference on Email and Anti-Spam. Crystal Drive: CEAS, 2009.

84.Bitaab M, Cho H, Oest A et al. Scam pandemic: how attackers exploit public fear through phishing. In: Proceedings of the 2020 APWG Symposium on Electronic Crime Research (eCrime). Boston, MA, USA: IEEE, 2020, 1–10.

85.Roy SS, Karanjit U, Nilizadeh S. Evaluating the effectiveness of phishing reports on twitter. In: Proceedings of the 2021 APWG Symposium on Electronic Crime Research (eCrime). Boston, MA, USA: IEEE, 2021, 1–13.

86.Roy SS, Karanjit U, Nilizadeh S. What remains uncaught?: Characterizing sparsely detected malicious urls on twitter. In: Proceedings of the Network and Distributed Systems Security (NDSS). Network and Distributed System Security (NDSS) Virtual. 2021, 400–12.

87.Saha Roy S, Karanjit U, Nilizadeh S. Phishing in the free waters: a study of phishing attacks created using free website building services. In: Proceedings of the 2023 ACM on Internet Measurement Conference. IMC '23. New York, NY, USA: Association for Computing Machinery, 2023, 268–81.

88.Moore T, Clayton R. The consequence of non-cooperation in the fight against phishing. In: Proceedings of the 2008 APWG eCrime Researchers Summit. Atlanta, GA, USA: IEEE, 2008, 1–14.

89.Borgolte K, Fiebig T, Hao S et al. Cloud strife: mitigating the security risks of domain-validated certificates. In: Proceedings of the 2018 Applied Networking Research Workshop. ANRW '18. New York, NY, USA: Association for Computing Machinery, 2018, 4.

90.Moore T, Clayton R, Stern H. Temporal correlations between spam and phishing websites. In: Proceedings of the 2nd USENIX Conference on Large-Scale Exploits and Emergent Threats: Botnets, Spyware, Worms, and More. LEET'09. Boston, MA, USA: USENIX Association, 2009, 5.

91.Hutchings A, Clayton R, Anderson R. Taking down websites to prevent crime. In: Proceedings of the 2016 APWG Symposium on Electronic Crime Research (eCrime). Toronto, ON, Canada: IEEE, 2016, 1–10.

92.Anti-Phishing Working Group (APWG). The APWG eCrime Exchange (ECX). 2024. https://apwg.org/ecx/ (1 August 2024, date last accessed).

93.Daigle L. WHOIS protocol specification. 2004. https://www.rfc-editor.org/rfc/rfc3912 (1 August 2024, date last accessed).

94.IPinfo. The trusted source for IP address data. https://ipinfo.io/ (1 August 2024, date last accessed).

95.Team Cymru. IP to ASN mapping service. https://www.team-cymru.com/ip-asn-mapping (1 August 2024, date last accessed).

96.Paul A. crtsh 0.3.1. 2021. https://pypi.org/project/crtsh/ (1 August 2024, date last accessed).

97.Weimer F. Passive DNS replication. In: Proceedings of the FIRST Conference on Computer Security Incident. Vol. 98. Singapore: FIRST, 2005, 1–14.

98.Spamhaus Technology. Passive DNS. https://www.spamhaus.com/product/passive-dns/.

99.VirusTotal. What is the difference between the public API and the private API?. https://docs.virustotal.com/docs/difference-public-private (1 August 2024, date last accessed).

100.Google. Safe browsing APIs (v4). 2024. https://developers.google.com/safe-browsing/v4/ (1 August 2024, date last accessed).

101.Google Safe Browsing. Google transparency report. https://transparencyreport.google.com/safe-browsing/search (1 August 2024, date last accessed).

102.Clayton R, Moore T, Christin N. Concentrating correctly on cybercrime concentration. In: Workshop on the Economics of Information Security. Delft, Netherlands: WEIS, 2015.

103.Sommese R, Akiwate G, Affinito A et al. DarkDNS: revisiting the value of rapid zone Update. In: Proceedings of the 2024 ACM on Internet Measurement Conference. IMC '24. New York, NY, USA: Association for Computing Machinery, 2024, 454–61.

104.Internet Assigned Numbers Authority (IANA). List of top-level domains. 2024. https://data.iana.org/TLD/tlds-alpha-by-domain.txt (1 August 2024, date last accessed).

105.Spamhaus. Reputation Statistics | General Top-Level Domains (gTLDs). 2024. https://www.spamhaus.org/reputation-statistics/gtlds/phishing/ (1 August 2024, date last accessed).

106.Korczynski M, Tajalizadehkhoob S, Noroozian A et al. Reputation metrics design to improve intermediary incentives for security of TLDs. In: Proceedings of the 2017 IEEE European Symposium on Security and Privacy (EuroS&P). Paris, France: IEEE, 2017, 579–94.

107.Timko D, Rahman ML. Smishing Dataset I: phishing SMS dataset from Smishtank.com. In: Proceedings of the Fourteenth ACM Conference on Data and Application Security and Privacy. CODASPY '24. New York, NY: Association for Computing Machinery, 2024, 289–94.

108.Kaspersky Lab. Distribution of top-level domains used by phishing sites in 2022. 2023. https://www.statista.com/statistics/1256788/phishing-sites-tlds/ (1 August 2024, date last accessed).

109.BlueCat. Which top-level domains to block and how to do it right. 2024. https://bluecatnetworks.com/blog/which-top-level-domains-to-block-and-how-to-do-it-right/ (1 November 2024, date last accessed).

110.Deola E. How to block top-level domains (TLD's). 2024. https://flashstart.com/how-to-block-top-level-domains-tlds/ (1 November 2024, date last accessed).

111.Szurdi J. A peek into top-level domains and cybercrime. CA, USA. 2021. https://unit42.paloaltonetworks.com/top-level-domains-cybercrime/ (1 June 2024, date last accessed).

112.WhoisXMLAPI. Global Domain Activity Report Q3 2023. 2023. https://publishing-platform.whoisxmlapi.com/wordpress/wp-content/uploads/2023/11/Global-Domain-Activity-Report-Q3-2023.pdf (1 June 2024, date last accessed).

113.WhoisXMLAPI. Global Domain Activity Report Q4 2023. 2024. https://publishing-platform.whoisxmlapi.com/wordpress/wp-content/uploads/2024/01/2024015-Global-Domain-Activity-Report-Q4-2023.pdf (1 June 2024, date last accessed).

114.WhoisXMLAPI. Global Domain Activity Report Q1 2024. 2024. https://publishing-platform.whoisxmlapi.com/wordpress/wp-content/uploads/2024/04/20240415-Global-Domain-Activity-Report-Q1-2024.pdf (1 June 2024, date last accessed).

115.WhoisXMLAPI. Global Domain Activity Report Q2 2024. 2024. https://publishing-platform.whoisxmlapi.com/wordpress/wp-content/uploads/2024/07/20240716-Q2-2024-Global-Domain-Activity-Report.pdf (1 November 2024, date last accessed).

116.W3Techs. Most popular top-level domains worldwide as of December 2023 [Graph]. 2023. https://www.statista.com/statistics/265677/number-of-internet-top-level-domains-worldwide/ (1 June 2024, date last accessed).

117.Szurdi J, Christin N. Domain registration policy strategies and the fight against online crime. In: Workshop on the Economics of Information Security. Innsbruck, Austria: WEIS, 2018.

118.Liu HL, Levchenko K, Felegyhazi M et al. On the effects of registrar-level intervention. In: Proceedings of the 4th USENIX Conference on Large-Scale Exploits and Emergent Threats: Botnets, Spyware, Worms, and More. LEET'11. Boston, MA, USA: USENIX Association, 2011.

119.DomainTools. Domain count statistics for TLDs. https://research.domaintools.com/statistics/tld-counts/ (1 June 2024, date last accessed).

120.Moore T, Clayton R. The impact of incentives on notice and take-down. In: Managing Information Risk and the Economics of Security. New York: Springer, 2008, 199–223.

121.Anti-Phishing Working Group (APWG). Phishing activity trends report 1st quarter 2024. 2024. https://docs.apwg.org/reports/apwg_trends_report_q1_2024.pdf (1 June 2024, date last accessed).

122.Anti-Phishing Working Group (APWG). Phishing activity trends report 4th quarter 2023. 2023. https://docs.apwg.org/reports/apwg_trends_report_q4_2023.pdf (1 June 2024, date last accessed).

123.Domain Name Stat. Domain name registrars list - domain name stat. 2024. https://domainnamestat.com/statistics/registrar/others (1 June 2024, date last accessed).

124.Spamhaus. Reputation statistics | Registrars. 2024. https://www.spamhaus.org/reputation-statistics/registrars/phishing/ (1 June 2024, date last accessed).

125.Leontiadis N, Moore T, Christin N. Measuring and analyzing \lbraceSearch-Redirection\rbrace attacks in the illicit online prescription drug trade. In: Proceedings of the 20th USENIX Security Symposium (USENIX Security 11). San Francisco, CA, USA: USENIX Association, 2011.

126.W3Techs. Historical trends in the usage statistics of reverse proxy services for websites. 2024. https://w3techs.com/technologies/history_overview/proxy/all (1 June 2024, date last accessed).

127.URLhaus. URLhaus ASN CSV Feed. Switzerland. 2024. https://urlhaus.abuse.ch/feeds/asn/200593/ (1 June 2024, date last accessed).

128.WhoisXML API. Uncovering suspicious download pages linked to app installer abuse. 2024. https://circleid.com/posts/20240409-uncovering-suspicious-download-pages-linked-to-app-installer-abuse (1 June 2024, date last accessed).

129.Brilliance Security Magazine. Thwarting a Russian-based cyberattack on a global bank. 2023. https://brilliancesecuritymagazine.com/cybersecurity/thwarting-a-russian-based-cyberattack-on-a-global-bank/ (1 June 2024, date last accessed).

130.Lopez A. HYAS insight uncovers and mitigates russian-based cyberattack. 2023. https://www.hyas.com/blog/hyas-insight-uncovers-and-mitigates-a-russian-based-cyberattack (1 June 2024, date last accessed).

131.Sectigo. Buy SSL/TLS certificates. https://www.sectigo.com/ssl-certificates-tls (1 June 2024, date last accessed).

132.Aas J, Barnes R, Case B et al. Let's Encrypt: an automated certificate authority to encrypt the entire web. In: Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security. CCS '19. New York, NY, US: Association for Computing Machinery, 2019, 2473–87.

133.Let's Encrypt. The CA's role in fighting phishing and malware. https://letsencrypt.org/2015/10/29/phishing-and-malware/ (1 June 2024, date last accessed).

134.BuiltWith. SSL providers web usage distribution. 2024. https://trends.builtwith.com/ssl (1 June 2024, date last accessed).

135.W3Techs. Usage statistics and market shares of SSL certificate authorities for websites. 2024. https://w3techs.com/technologies/overview/ssl_certificate (1 June 2024, date last accessed).

136.Proofpoint. state of the phish. 2024. https://www.proofpoint.com/sites/default/files/threat-reports/pfpt-us-tr-state-of-the-phish-2024.pdf (1 June 2024, date last accessed).

137.Anderson R, Barton C, Böhme R et al. Measuring the cost of cybercrime. In: Workshop on the Economics of Information Security. Berlin, Heidelberg: Springer, 2013, 265–300.

138.Anderson R, Barton C, Böhme R et al. Measuring the changing cost of cybercrime. In: Workshop on the Economics of Information Security. Boston, MA, USA: WEIS, 2019.

139.UPS. Scam text examples. 2022. https://www.ups.com/assets/resources/webcontent/en_GB/scam-text-examples.pdf (1 June 2024, date last accessed).

140.UPS. Examples of fraudulent emails. 2022. https://www.ups.com/assets/resources/webcontent/en_GB/fraud_email_examples.pdf (1 June 2024, date last accessed).

141.Peachey K. Parcel delivery texts now the most common con-trick. London, UK: BBC, 2021. https://www.bbc.co.uk/news/business-58233743 (1 June 2024, date last accessed).

142.Citizens Advice. Scams linked to parcel deliveries come top in 2023. London, UK, 2023. https://www.citizensadvice.org.uk/about-us/media-centre/press-releases/scams-linked-to-parcel-deliveries-come-top-in-2023/ (1 June 2024, date last accessed).

143.Wearn R. Parcel delivery scam texts to spike this Christmas. London, UK: BBC, 2021. https://www.bbc.co.uk/news/business-59760326 (1 June 2024, date last accessed).

144.Cova M, Kruegel C, Vigna G. There Is no free phish: an analysis of "Free" and live phishing kits. In: Proceedings of the 2nd Conference on USENIX Workshop on Offensive Technologies. WOOT'08. San Jose, CA, USA: USENIX Association, 2008, 1–8.

145.Feal Á, Vallina P, Gamba J et al. Blocklist babel: on the transparency and dynamics of open source blocklisting. IEEE T Netw Serv Man. 2021;18:1334–49.

146.Peng P, Yang L, Song L et al. Opening the blackbox of VirusTotal: analyzing online phishing scan engines. In: Proceedings of the Internet Measurement Conference. IMC '19. New York, NY: Association for Computing Machinery, 2019, 478–85.

147.Korczynski M, Wullink M, Tajalizadehkhoob S et al. Cybercrime after the sunrise: a statistical analysis of DNS abuse in new gTLDs. In: Proceedings of the 2018 on Asia Conference on Computer and Communications Security. ASIACCS ’18. New York, NY, USA: Association for Computing Machinery, 2018, 609–23.

148.NCSC. Active cyber defence: the fourth year. United Kingdom: NCSC, 2020. https://www.ncsc.gov.uk/files/Active-Cyber-Defence-ACD-The-Fourth-Year.pdf (1 June 2024, date last accessed).

149.Noroozian A, Korczynski M, TajalizadehKhoob S et al. Developing security reputation metrics for hosting providers. In: Proceedings of the 8th USENIX Conference on Cyber Security Experimentation and Test. CSET’15. Washington, D.C., USA: USENIX Association, 2015, 5.

150.Shue CA, Kalafut AJ, Gupta M. Abnormally malicious autonomous systems and their internet connectivity. IEEE ACM T Netw. 2012;20:220–30.

151.Mahjoub D. Sweeping the IP Space: the hunt for evil on the internet. In: Virus Bulletin Conference. Seattle, WA, USA: Virus Bulletin, 2014.

152.Censys. Hiding in plain sight: tracking bulletproof hosting and abused RDP infrastructure. Censys USA. https://censys.com/blog/hiding-in-plain-sight-tracking-bulletproof-hosting-and-abused-rdp-infrastructure/ (1 March 2026, date last accessed).

153.Alowaisheq E. Cracking wall of confinement: understanding and analyzing malicious domain takedowns. In: Proceedings of the Network and Distributed System Security Symposium (NDSS). San Diego, CA, USA: Network and Distributed Systems Security (NDSS), 2019.

154.Collier B, Clayton R. Peer(ing) pressure: a cybersecurity intervention at global scale in the internet infrastructure. J Cybersecur. 2025;11:tyaf014.

155.Ho H, Ko R, Mazerolle L et al. Using Situational Crime Prevention (SCP)-C3 cycle and common inventory of cybersecurity controls from ISO/IEC 27002:2022 to prevent cybercrimes. J Cybersecur. 2024;10:tyae020.

156.Aas J. Let’s encrypt no longer checking google safe browsing. San Francisco, CA, USA: Lets Encrypt, 2019. https://community.letsencrypt.org/t/let-s-encrypt-no-longer-checking-google-safe-browsing/82168 (1 June 2024, date last accessed).

157.Aas J. The CA’s role in fighting phishing and malware. San Francisco, CA, USA: Lets Encrypt, 2015. https://letsencrypt.org/2015/10/29/phishing-and-malware.html (1 June 2024, date last accessed).

158.Spring JM. Modeling malicious domain name take-down dynamics: why eCrime pays. In: Proceedings of the 2013 APWG eCrime Researchers Summit. San Francisco, CA, USA: IEEE, 2013, 1–9.

© Các tác giả, 2026. Oxford University Press xuất bản.

Đây là bài báo truy cập mở, phân phối theo giấy phép Creative Commons Attribution — CC BY 4.0 (https://creativecommons.org/licenses/by/4.0/), cho phép tái sử dụng, phân phối và sao chép không hạn chế bằng mọi phương tiện, với điều kiện trích dẫn đúng công trình gốc.